

ALLGEMEINES KI-IT-SICHERHEITSKONZEPT

Sicherheitskonzept für vollständig lokale KI-Infrastrukturen

ÖFFENTLICH – organisationsneutrale Referenzvorlage

Version 0.1.0 · Fachlicher Stichtag 03.09.2026

Dokumentenlenkung

Merkmal	Festlegung
Dokumenttitel	Allgemeines KI-IT-Sicherheitskonzept
Dokumentstatus	ÖFFENTLICH – organisationsneutrale Referenzvorlage
Version	0.1.0
Fachlicher Stichtag	03.09.2026
Normative Anforderungen	KI-IT-Sicherheitskatalog nach Open Security Controls Assessment Language (OSCAL) 1.1.3
OSCAL-Fassung	1.1.3
Betriebsmodell	Vollständig lokal; externe Inferenz nicht anwendbar
Modelländerung	Training und Feinabstimmung ausgeschlossen

Inhaltsverzeichnis

1 Dokumentenstatus und Geltungsbereich	4
2 Zweck, Zielgruppe und Abgrenzung	5
2.1 Zentrale Begriffe.....	5
3 Voraussetzungen des allgemeinen IT-Sicherheitskonzepts.....	6
4 Lokale KI-Systemarchitektur.....	7
5 Systemgrenzen, Vertrauenszonen und Datenflüsse	8
5.1 Kommunikations- und Importregeln	8
6 Rechts-, Normen- und Anwendbarkeitsmatrix	10
7 Steuerung, Rollen und Verantwortlichkeiten	11
8 KI-Risiko- und Bedrohungsmodell.....	12
8.1 Bewertungsverfahren.....	12
8.2 Bewertungsmaßstab und Freigabegrenzen.....	12
8.3 Risikoregister der Standardarchitektur	13
9 KI-spezifische Sicherheitsmaßnahmen	15
9.1 Geltungsbereich und Abhängigkeit vom Basis-Sicherheitskonzept	15
9.2 KI-Steuerung, Inventar, Rollen und Nutzungsgenehmigung	17
9.3 Recht, Datenschutz, Mitbestimmung, Schutzbedarf und Geheimschutzfreigaben	20
9.4 Lokale Systemarchitektur und Vertrauensgrenzen	22
9.5 Container-, Inferenz- und API-Sicherheit.....	24
9.6 Modellbeschaffung, Herkunftsnachweis, Integrität und Austausch	28
9.7 Ausdrückliches Trainings- und Feinabstimmungsverbot.....	30
9.8 Sicherheit der lokalen Wissenssuche, Suchvektoren und Dateiübernahmen	31
9.9 Identitäten, Rollen, technische Konten und Geheimnisse	35
9.10 Chat-Oberflächen und agentische Clientanwendungen	36
9.11 Eingeschleuste Anweisungen, Datenabfluss und unsichere Modellausgaben	38
9.12 Werkzeugnutzung, Dateizugriff und Befehlsausführung.....	40
9.13 Gezielte Angriffe, Modellmissbrauch und Ressourcenerschöpfung	42
9.14 Bewertung, Freigabe, Wiederholungsprüfung und Rückkehr zur Vorversion.....	44
9.15 Protokollierung, Überwachung, Verhaltensänderungen, Vorfälle und Wiederanlauf	46
9.16 Außerbetriebnahme und nachweisbare Löschung.....	49
9.17 Bedingte Anforderungen für externe Inferenz.....	50
9.18 Nachweise, Ausnahmen und akzeptierte Restrisiken	52
10 Lokale Wissenssuche, Dateiübernahmen und Daten.....	53
11 Agentische Anwendungen und lokale Entwicklungsumgebungen.....	54
12 Betrieb, Änderung, Modellwechsel, Vorfälle und Außerbetriebnahme.....	55
13 Nachweis-, Prüf- und Zuordnungsübersicht.....	56
14 Quellenverzeichnis und Abkürzungen	60
14.1 Quellenverzeichnis	60
14.2 Abkürzungen	64

1 Dokumentenstatus und Geltungsbereich

Das Konzept trägt den Status ÖFFENTLICH – organisationsneutrale Referenzvorlage. Es gilt für die organisationsneutrale Standardarchitektur einer vollständig lokalen generativen KI-Umgebung mit verwalteten Clients, kontrolliertem KI-Zugang und getrennter KI-Serverzone.

Der Status ÖFFENTLICH gilt nur für die organisationsneutrale Fassung. Sobald reale Organisations-, Infrastruktur-, Schutzbedarfs-, Konto- oder Schwachstelleninformationen aufgenommen werden, ist die Fassung getrennt zu führen, angemessen zu schützen und durch die zuständigen Stellen einzustufen und freizugeben.

2 Zweck, Zielgruppe und Abgrenzung

Dieses Sicherheitskonzept regelt Planung, Freigabe, Betrieb, Änderung und Außerbetriebnahme lokaler generativer KI-Dienste. Es richtet sich an Leitung, Informationssicherheit, Datenschutz, Recht, Geheimschutz, Personalvertretung und Fachverantwortung sowie an Rollen für Architektur, Plattform, Netzwerk, Identität, lokale Wissenssuche, Modelle, Tests und Betrieb.

Nicht Gegenstand sind eine produktive Plattform, Beschaffungsempfehlungen, Training, Feinabstimmung, kontinuierliches Lernen oder die pauschale Freigabe eines konkreten Anwendungsfalls. Fachwissen wird ausschließlich aus lokalen Wissensbeständen oder aus kontrollierten, zeitlich begrenzten Dateiübernahmen bereitgestellt.

2.1 Zentrale Begriffe

Lokale Inferenz: Ausführung eines vortrainierten Modells innerhalb der eigenen Infrastruktur, ohne beabsichtigte Änderung der Modellgewichte.

Lokale Wissenssuche (RAG): Suche nach freigegebenen Textausschnitten, die der lokalen Inferenz als zusätzlicher Kontext übergeben werden.

Suchvektor (Embedding): Numerische Darstellung eines Inhalts für die Ähnlichkeitssuche. Der Schutzbedarf der Quelldaten kann darin erhalten bleiben.

Bedarfsgesteuerte Dateiübernahme: Zeitlich begrenzte Übergabe einer Datei an die lokale KI-Umgebung. Ohne ausdrückliche Freigabe bleibt die Verarbeitung auf die Sitzung begrenzt.

Programmierschnittstelle (API): Technischer Zugang, über den ein Client festgelegte Funktionen eines Dienstes aufruft.

Identitätsdienst (IdP): Lokaler Dienst, der Personen und technische Konten verlässlich identifiziert und deren Anmeldung unterstützt.

Transportverschlüsselung (TLS): Verschlüsselung einer Netzwerkverbindung zum Schutz vor Mitlesen und Veränderung während der Übertragung.

Zentrale Sicherheitsauswertung (SIEM): Lokale Sammlung und Auswertung sicherheitsrelevanter Protokollereignisse.

Model Context Protocol (MCP): Technisches Protokoll zur Anbindung zusätzlicher Werkzeuge oder Datenquellen an eine agentische Anwendung.

Agentische Anwendung: Client oder Dienst, der einen Modellvorschlag in einen Datei-, Werkzeug-, Befehls- oder Netzwerkzugriff überführen kann.

Eingeschleuste Anweisung (Prompt Injection): Anweisung in einer Eingabe, einem Dokument oder einer Werkzeugausgabe, die festgelegte Regeln oder Berechtigungsgrenzen umgehen soll.

Herkunftsnachweis: Nachvollziehbare Kette von der veröffentlichten Quelle eines Modells, Pakets oder Dokuments bis zum tatsächlich verwendeten Artefakt.

Ausgehende Verbindung: Netzwerkverbindung aus der KI-Umgebung zu einem Ziel außerhalb der freigegebenen lokalen Systemgrenze.

Zugriffsregel (ACL): Technische Liste, die festlegt, welche Identität auf welche Daten oder Funktionen zugreifen darf.

Restrisiko: Risiko, das nach Umsetzung und Prüfung der vorgesehenen Sicherheitsmaßnahmen verbleibt.

3 Voraussetzungen des allgemeinen IT-Sicherheitskonzepts

Der sichere KI-Betrieb setzt ein wirksames allgemeines IT-Sicherheitskonzept und einen festgelegten Informationsverbund voraus. Die KI-spezifischen Maßnahmen ergänzen diesen Sicherheitsprozess dort, wo Modelle, Wissensbestände, Eingaben oder automatisierte Werkzeugzugriffe zusätzliche Risiken erzeugen:¹

- Verwaltete Clients und Server, sichere Domäne, lokaler Identitätsdienst, Rollen und Multifaktorauthentisierung (MFA).
- Interne Zertifikatsinfrastruktur (PKI), vertrauenswürdige Zertifikate, Segmentierung, Firewalls und abgesicherter Fernzugriff.
- Patch-, Schwachstellen-, Konfigurations- und sichere Softwareverteilung.
- Lokale Protokollierung, Überwachung, Datensicherung, Wiederherstellung, Notfallmanagement und Schadsoftwareschutz.

Fehlende Basismaßnahmen sperren die Freigabe der abhängigen KI-Funktion. Sie werden im allgemeinen Sicherheitsprozess behandelt und nicht durch KI-spezifische Einzelmaßnahmen ersetzt.

¹ Bundesamt für Sicherheit in der Informationstechnik: BSI-Standard 200-2: IT-Grundschutz-Methodik, Version 1.0, Stand Oktober 2017, S. 11, S. 69–74 und S. 154–156, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/BSI_Standards/standard_200_2.pdf?__blob=publicationFile&v=2, abgerufen am 03.09.2026.

4 Lokale KI-Systemarchitektur

Die Systemarchitektur ist vollständig lokal. Verwaltete Clients erreichen über HTTPS ausschließlich den kontrollierten internen KI-Zugang. Dahinter liegt eine getrennte KI-Serverzone mit Containerplattform, Chat-Oberfläche, lokaler Inferenz, lokaler Wissenssuche, Suchvektoren, Treffer-Neusortierung, Datenhaltung und technischer Überwachung. Fernzugriff erfolgt nur über ein organisationskontrolliertes virtuelles privates Netz (VPN) mit Mehrfaktorauthentisierung.

Der kontrollierte KI-Zugang ist der einzige zulässige Anfragepfad aus der Clientzone. Identitätsdienst, Verwaltungszugang, lokale Registrierungen und Prüfprotokolle sind vom normalen Anfragepfad getrennt. Die Inferenz besitzt keine ausgehende Internetverbindung (Abbildung 1).

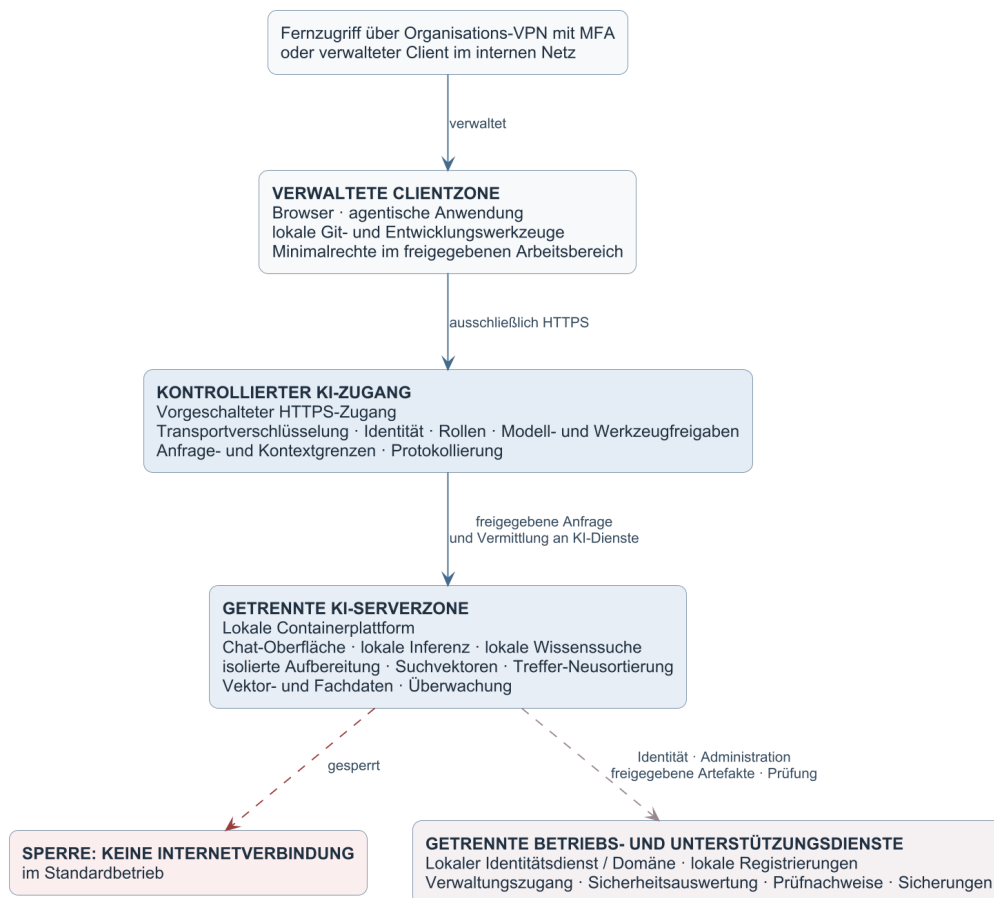


Abbildung 1: Nur der kontrollierte KI-Zugang verbindet die Clientzone mit der abgeschotteten KI-Serverzone.

5 Systemgrenzen, Vertrauenszonen und Datenflüsse

Jede Vertrauenszone besitzt eine klar abgegrenzte Aufgabe. Übergänge zwischen den Zonen werden authentisiert, protokolliert und auf die ausdrücklich freigegebenen Kommunikationsbeziehungen begrenzt.

Vertrauenszone	Aufgabe und Grenze
Verwaltete Clientzone	Benutzerinteraktion, lokale Entwicklungswerkzeuge und begrenzte agentische Aktionen.
Kontrollierter KI-Zugang	Einziger Clientpfad; Identität, Rollen, Transportverschlüsselung sowie Modell-, Kontext-, Raten- und Werkzeugregeln.
KI-Serverzone	Interne Inferenz-, Wissens-, Daten- und Überwachungsdienste ohne Erreichbarkeit aus öffentlichen oder allgemeinen Clientnetzen.
Importweg	Prüfung von Modellen, Containerabbildern, Paketen und Erweiterungen vor der Übernahme in lokale Registrierungen.
Betriebs- und Nachweisbereich	Besonders geschützte Protokolle, Sicherheitsauswertungen, Freigaben, Sicherungen und Wiederherstellungsdaten.

5.1 Kommunikations- und Importregeln

Ein internes Container- oder Pod-Netz ist keine ausreichende Sicherheitsgrenze. Kommunikationsbeziehungen werden standardmäßig verweigert und einzeln erlaubt. Inferenz-, Administrations-, Diagnose-, Metrik-, Cluster- und Zwischenspeicher-Schnittstellen bleiben vom normalen Netz getrennt.

Identitäten, Git, Modelle, Dokumente, Suchvektoren, Indizes, Chats, Protokolle, Telemetrie und Sicherungen verbleiben lokal. Externe Artefakte gelangen ausschließlich über eine getrennte Prüfzone, kontrollierte Übertragung, lokale Registrierung und Freigabe in die Produktionsumgebung (Abbildung 2).

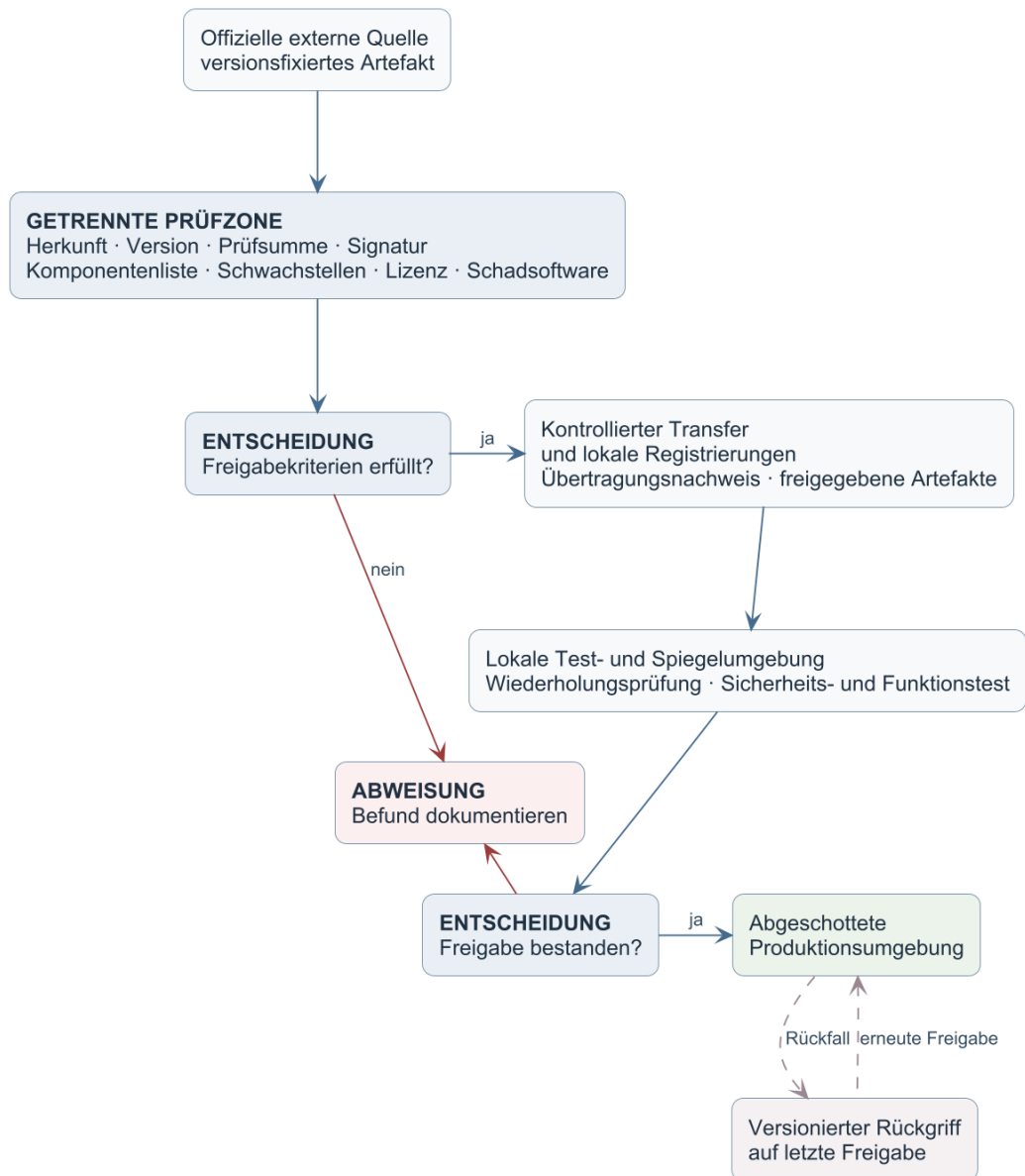


Abbildung 2: Nur geprüfte und freigegebene Artefakte erreichen die abgeschottete Produktionsumgebung.

6 Rechts-, Normen- und Anwendbarkeitsmatrix

Vor der Freigabe eines Anwendungsfalls bestimmen die zuständigen Funktionen die anwendbaren Rechtsgrundlagen, Beteiligungsrechte, behördlichen Vorgaben und Freigabebedingungen. Die Ergebnisse werden als technische oder organisatorische Bedingungen umgesetzt.

Grundlage	Anwendbarkeit	Prüf- und Festlegungsbedarf	Quellen
KI-Verordnung (EU) 2024/1689	Anwendungsfallbezogen	Rolle, Risikoklasse, Betreiberpflichten, KI-Kompetenz und Folgenabschätzung prüfen.	Q-EU-001
Datenschutzrecht	Bei personenbezogenen Daten	Rechtsgrundlage, Zweck, Minimierung, Rollen, Transparenz, Rechte, Löschung und Folgenabschätzung prüfen.	Q-BFDI-001; Q-DSK-001 bis Q-DSK-003
BSIG und adressatenbezogene BSI-Vorgaben	Organisationsspezifisch	Adressat, Verbindlichkeit, Basis-Sicherheitskonzept und Nachweispflichten feststellen.	Q-BSIG-001; Q-BSI-001
Geheimschutz	Bei entsprechend geschützten Inhalten	Verarbeitung nur nach befugter Einstufung, Systemzulässigkeit und ausdrücklicher Freigabe.	Q-SUEG-001; Q-VSA-001
ISO/IEC 27001 und 27002	Orientierende Zuordnung	Lizenzierte Normtexte und unabhängige Bewertung für eine Konformitätsaussage erforderlich.	Q-ISO-27001; Q-ISO-27002
ISO/IEC 42001, 23894, 42005, 5338, 5259, 25059	Orientierende KI-Zuordnung	Nur öffentliche Metadaten und Kennungen; keine Wiedergabe proprietärer Anforderungen.	Q-ISO-42001; Q-ISO-23894; Q-ISO-42005; Q-ISO-5338; Q-ISO-5259; Q-ISO-25059

7 Steuerung, Rollen und Verantwortlichkeiten

Entscheidungs-, Umsetzungs- und Prüffunktionen werden so getrennt, dass Freigaben und wesentliche Restrisiken nachvollziehbar verantwortet werden. Eine Person darf mehrere Rollen wahrnehmen, sofern Interessenkonflikte behandelt und notwendige unabhängige Prüfungen erhalten bleiben.

Rolle	Kernverantwortung
Leitung	Risikobereitschaft, Ressourcen, wesentliche Restrisiken und Freigabeframework.
KI-Verantwortliche	Inventar, Anwendungsfälle, Modell- und Richtlinienfreigaben sowie koordinierter Lebenszyklus.
Informationssicherheit	Bedrohungsmodell, Kontrollanforderungen, Prüfung, Vorfälle und Basis-ISMS-Verknüpfung.
Datenschutz, Recht, Geheimenschutz, Personalvertretung	Anwendbarkeitsprüfung, Beteiligung, Bedingungen und befugte Freigaben im jeweiligen Zuständigkeitsbereich.
Architektur, Netz, Plattform, Identität und KI-Zugang	Technische Zonen, ausgehender Netzwerkverkehr, freigegebener Laufzeitstand, Identitäten, Zertifikate und Richtliniendurchsetzung.
Modell, Wissenssuche, Daten und Werkzeuge	Herkunftsnachweis, Integrität, Zugriffsregeln, Löschung, Erweiterungsfreigabe und fachliche Datenverantwortung.
Test und Betrieb	Reproduzierbare Bewertung, Wiederholungsprüfung, Überwachung, Protokollierung, Wiederanlauf und Außerbetriebnahme.
Nutzende	Zweckgebundene Nutzung, Schutzregeln, Ergebnisprüfung und Meldung von Auffälligkeiten.

8 KI-Risiko- und Bedrohungsmodell

8.1 Bewertungsverfahren

Jedes Risiko wird als nachvollziehbares Szenario aus Ursache, betroffenem Wert und möglicher Auswirkung beschrieben. Danach werden Eintrittshäufigkeit und Schadenshöhe unter Berücksichtigung bereits wirksamer Maßnahmen eingeschätzt. Die Risikokategorie bestimmt die Behandlung. Nach Umsetzung und Prüfung zusätzlicher Maßnahmen wird das Restrisiko erneut eingestuft und einer verantwortlichen Entscheidung zugeführt.²

Die Bewertung erfasst Eingaben, Modelle, Systemanweisungen, lokale Wissensuche, Werkzeuge, Clients, Schnittstellen, Plattform, Protokolle und Importwege. Änderungen oder abgelaufene Prüffristen führen zurück in die vollständige Bewertung (Abbildung 3).

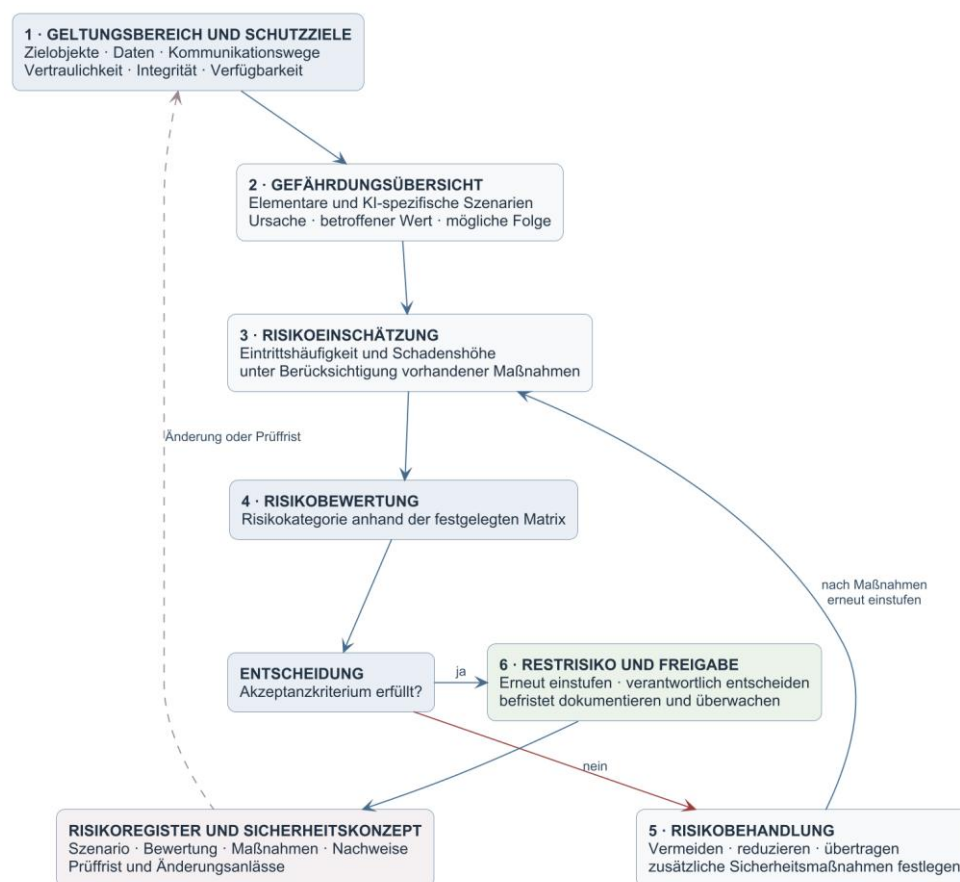


Abbildung 3: Risiken werden szenariobezogen behandelt und bis zur Freigabe erneut bewertet.

8.2 Bewertungsmaßstab und Freigabegrenzen

Die Eintrittshäufigkeit wird als selten, mittel, häufig oder sehr häufig eingestuft. Die Schadenshöhe wird als vernachlässigbar, begrenzt, beträchtlich oder existenzbedrohend bewertet. Die Kombination

² Bundesamt für Sicherheit in der Informationstechnik: BSI-Standard 200-3: Risikomanagement, Version 1.0, Stand Oktober 2017, S. 5–7, S. 26–28 und S. 33–35, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/BSI_Standards/standard_200_3.pdf?__blob=publicationFile&v=2, abgerufen am 03.09.2026.

ergibt die Risikokategorie gering, mittel, hoch oder sehr hoch. Jede Matrixzelle nennt die Kategorie als Text; die Farbe dient nur der schnellen Orientierung.

Schadenshöhe / Eintrittshäufigkeit	selten	mittel	häufig	sehr häufig
existenzbedrohend	mittel	hoch A: R-08	sehr hoch	sehr hoch
beträchtlich	mittel R: R-01, R-02, R-03 R-04, R-07, R-09	mittel A: R-02, R-04	hoch A: R-01, R-03, R-06, R-09	sehr hoch A: R-07
begrenzt	gering R: R-05, R-08	gering R: R-06	mittel A: R-05	hoch
vernachlässigbar	gering	gering	gering	gering

A = Ausgangsrisiko vor den KI-spezifischen Kontrollen
R = Restrisiko nach den Kontrollen
Jede Zelle nennt die Risikokategorie zusätzlich als Text; Farbe ist nur eine ergänzende Orientierung.

Abbildung 4: Die KI-spezifischen Maßnahmen senken alle hohen und sehr hohen Ausgangsrisiken auf höchstens mittel.

- Geringe Risiken dürfen durch die zuständige Rolle akzeptiert und überwacht werden.
- Mittlere Risiken dürfen nur befristet, mit benannter Verantwortung, Maßnahmenplan und Prüftermin akzeptiert werden.
- Hohe und sehr hohe Risiken sperren die Erstfreigabe oder den Weiterbetrieb, bis zusätzliche Maßnahmen nachweislich wirken.
- Jede Akzeptanz nennt Begründung, Entscheidung, Gültigkeitsfrist und erneuten Bewertungsanlass.

8.3 Risikoregister der Standardarchitektur

Die Risikobewertung wird vor der Erstinutzung, mindestens jährlich sowie nach wesentlichen Änderungen, Sicherheitsvorfällen oder neuen Erkenntnissen wiederholt. Die folgende Bewertung gilt für die in diesem Konzept festgelegte Standardarchitektur und die vollständige Umsetzung der genannten Kontrollen.

ID	Risikoszenario	Ausgangsrisiko → Restrisiko	Behandlung und Kontrollen
R-01	Eine eingeschleuste Anweisung löst eine nicht erlaubte Werkzeugaktion aus.	häufig × beträchtlich = hoch → selten × beträchtlich = mittel	Kontexttrennung, Werkzeugrichtlinie, konkrete Bestätigung und Negativtests; KI-PMT-001, KI-TOL-001, KI-THR-001.
R-02	Ein manipuliertes Modell, Containerabbild oder Paket wird übernommen.	mittel × beträchtlich = mittel → selten × beträchtlich = mittel	Getrennte Importprüfung, Herkunftsnachweis, Signatur, Prüfsumme und Freigabe; KI-MOD-001, KI-TOL-002, KI-VAL-002.

ID	Risikoszenario	Ausgangsrisiko → Restrisiko	Behandlung und Kontrollen
R-03	Die lokale Wissenssuche gibt Inhalte ohne ausreichende Berechtigung aus.	häufig × beträchtlich = hoch → selten × beträchtlich = mittel	Zugriffsprüfung bei Aufnahme und Abfrage, getrennte Indizes und Löschtests; KI-RAG-002, KI-RAG-003.
R-04	Eine direkte Inferenzschnittstelle umgeht Identitäts- und Zugriffsregeln.	mittel × beträchtlich = mittel → selten × beträchtlich = mittel	Nur der kontrollierte KI-Zugang ist erreichbar; Rohschnittstellen bleiben abgeschottet; KI-API-001, KI-ARC-001.
R-05	Protokolle speichern mehr schutzbedürftige Inhalte als erforderlich.	häufig × begrenzt = mittel → selten × begrenzt = gering	Trennung von Sicherheitsmetadaten und Inhaltsdaten, Minimierung, Zugriff und Löschung; KI-OPS-001.
R-06	Lange Kontexte oder Agentenschleifen erschöpfen lokale Rechenressourcen.	häufig × beträchtlich = hoch → mittel × begrenzt = gering	Quoten, Zeitgrenzen, Warteschlangen, Prioritäten und sichere Beendigung; KI-THR-002.
R-07	Eine unzutreffende oder unsichere Ausgabe beeinflusst Entscheidungen oder Quellcode.	sehr häufig × beträchtlich = sehr hoch → selten × beträchtlich = mittel	Fachliche Prüfung, sichere Weiterverarbeitung, menschliche Freigabe und Wirksamkeitstests; KI-OUT-001, KI-VAL-001.
R-08	Eine Ausweichverbindung überträgt Eingaben unbeabsichtigt an einen externen Dienst.	mittel × existenzbedrohend = hoch → selten × begrenzt = gering	Deaktivierte externe Anbieter, gesperrter ausgehender Verkehr und negative Verbindungstests; KI-EXT-002, KI-ARC-002.
R-09	Ein Modell- oder Versionswechsel verschlechtert Sicherheit oder Ergebnisqualität.	häufig × beträchtlich = hoch → selten × beträchtlich = mittel	Gebundene Freigabestände, Wiederholungsprüfungen und getestete Rückkehr zur Vorversion; KI-MOD-002, KI-VAL-002.

9 KI-spezifische Sicherheitsmaßnahmen

Eine KI-Funktion darf nur freigegeben oder weiterbetrieben werden, wenn alle anwendbaren Anforderungen umgesetzt, geprüft und durch aktuelle Nachweise belegt sind. Abweichungen benötigen eine dokumentierte Behandlung und eine befristete, befugte Restrisikoentscheidung.

9.1 Geltungsbereich und Abhängigkeit vom Basis-Sicherheitskonzept

KI-GEL-001 – Abgrenzung zum allgemeinen IT-Sicherheitskonzept

Normative Anforderung

Für den Geltungsbereich MUSS ein wirksames allgemeines IT-Sicherheitskonzept eindeutig benannt werden. Die KI-spezifischen Kontrollen dürfen Basismaßnahmen nicht ersetzen; Abhängigkeiten, Verschärfungen und verbleibende Lücken MÜSSEN dokumentiert werden.

Begründung

KI-Komponenten erben Risiken aus Identitätsmanagement, Netzen, Plattformen und Betrieb. Ohne nachweisbare Basis kann die Wirksamkeit der Ergänzungen nicht beurteilt werden.

Umsetzung im Geltungsbereich

Eine Anwendbarkeitsmatrix verknüpft jede KI-Komponente mit den einschlägigen Basismaßnahmen und kennzeichnet ausschließlich die KI-spezifische Ergänzung. Fehlende Basiskontrollen werden außerhalb dieses Katalogs behandelt.

Prüfziel

Feststellen, ob Geltungsbereich, referenziertes Basis-Sicherheitskonzept und Abhängigkeiten vollständig und ohne Doppelzählung beschrieben sind.

Erwartete Nachweise

Freigegebenes Basis-Sicherheitskonzept; Anwendbarkeitsmatrix; Systemabgrenzung; dokumentierte Lücken und Verantwortlichkeiten.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Planung; Übernahme; Informationssicherheitsbeauftragte; KI-Verantwortliche; Systemverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: ISMS.1, ORP.1; ISO: ISO/IEC 27001:2022 4.3, ISO/IEC 27001:2022 6.1

Quellen

[Q-BSI-001] S. 4–5 und S. 11–12; [Q-BSI-2002-001] S. 11, S. 69–74 und S. 154–156; [Q-ISO-27001] öffentliche Metadaten; Zuordnung zu ISMS und Risikomanagement³

³ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 4–5 und S. 11–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-

KI-GEL-002 – Schutzkennzeichnung und kontrollierte Dokumentenführung

Normative Anforderung

Konzeptfassungen MÜSSEN ihrem Inhalt entsprechend gekennzeichnet, gespeichert und freigegeben werden. Sobald eine Fassung organisations- oder systemspezifische Informationen enthält, MUSS sie von der öffentlichen Fassung getrennt und angemessen geschützt werden; die formale Einstufung MUSS durch befugte Stellen erfolgen.

Begründung

Architektur-, Schutzbedarfs- und Schwachstellenangaben können den Schutzbedarf unmittelbar erhöhen. Eine technische Zugriffsbeschränkung ersetzt weder Kennzeichnung noch informationschutzrechtliche Freigabe.

Umsetzung im Geltungsbereich

Ein maschinenlesbarer Dokumentenstatus steuert Deckblatt, Kopfzeilen und Freigabeprüfungen. Automatisierte Suchregeln suchen ergänzend nach Infrastruktur- und Geheimnismustern, ersetzen aber keine manuelle Prüfung.

Prüfziel

Nachweisen, dass Kennzeichnung, Ablage und Freigabe dem Inhalt entsprechen und ein Wechsel zu organisations- oder systemspezifischen Informationen den erforderlichen Schutzstatus wirksam auslöst.

Erwartete Nachweise

Dokumentenstatus; negative Statustests; Freigabeprotokoll; Ergebnis der automatisierten Inhaltssuche; dokumentierte Zuständigkeit für Einstufungen.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Übernahme; Freigabe; Änderung; Informationssicherheitsbeauftragte; Geheimschutzbeauftragte; Dokumentenverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschatz: ORP.1, CON.10; ISO: ISO/IEC 27001:2022 5.2, ISO/IEC 27002:2022 5.12

Quellen

[Q-SUEG-001] § 4; [Q-VSA-001] allgemeine Einstufungs- und Handhabungsregeln; [Q-BMI-001] S. 26–27⁴

Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: BSI-Standard 200-2: IT-Grundschatz-Methodik, Version 1.0, Stand Oktober 2017, S. 11, S. 69–74 und S. 154–156, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschatz/BSI_Standards/standard_200_2.pdf?__blob=publicationFile&v=2, abgerufen am 03.09.2026. | International Organization for Standardization / International Electrotechnical Commission: Information security, cybersecurity and privacy protection — Information security management systems — Requirements, ISO/IEC 27001:2022, Stand ISO-Metadaten, Ausgabe 2022-10, veröffentlicht am 01.10.2022, öffentliche Metadaten; Zuordnung zu ISMS und Risikomanagement, <https://www.iso.org/standard/27001>, abgerufen am 02.09.2026.

⁴ Bundesrepublik Deutschland: Sicherheitsüberprüfungsgesetz, § 4 Verschlusssachen, SÜG, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 20.04.1994, § 4, https://www.gesetze-im-internet.de/s_g/_4.html, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat: Allgemeine Verwaltungsvorschrift zum materiellen Geheimschutz,

9.2 KI-Steuerung, Inventar, Rollen und Nutzungsgenehmigung

KI-GOV-001 – KI-Inventar und eindeutige Verantwortung

Normative Anforderung

KI-Systeme, Modelle, Schnittstellen, RAG-Bestände, agentische Werkzeuge, Anbieterabhängigkeiten und genehmigte Anwendungsfälle MÜSSEN in einem verantworteten Inventar geführt werden. Für jeden Eintrag MÜSSEN fachliche, technische, informationssicherheits- und datenschutzbezogene Rollen benannt sein.

Begründung

Nicht erfasste Modelle oder Integrationen entziehen sich Risiko-, Änderungs- und Außerbetriebnahmesteuerung.

Umsetzung im Geltungsbereich

Das Inventar enthält Version, Herkunft, Einsatzzweck, Datenarten, Schutzbedarf, Eigentümer, Freigabestatus, Abhängigkeiten und Ablauf der nächsten Überprüfung.

Prüfziel

Stichprobenartig prüfen, ob bereitgestellte Komponenten und genehmigte Nutzungen vollständig im Inventar abgebildet und Verantwortliche handlungsfähig sind.

Erwartete Nachweise

KI-Inventar; Rollenmatrix; Komponentenabgleich; Prüfprotokolle; Freigabestatus.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Planung; Beschaffung; Betrieb; Außerbetriebnahme; Leitung; KI-Verantwortliche; Systemverantwortliche; Datenschutzbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.1, OPS.1.1.2; ISO: ISO/IEC 42001:2023 A.3, ISO/IEC 27001:2022 5.3

Quellen

[Q-BSI-001] S. 8–10; [Q-BMVG-001] S. 24–28; [Q-EU-001] Art. 9 und 26⁵

Verschlusssachenanweisung, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 13.03.2023, allgemeine Einstufungs- und Handhabungsregeln, https://www.verwaltungsvorschriften-im-internet.de/bsvwvbund_13032023_SII554001405.htm, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, PDF-Stand 07.04.2025, S. 26–27, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026.

⁵ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 8–10, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 24–28, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | Europäische Union: Verordnung (EU) 2024/1689 über künstliche Intelligenz,

KI-GOV-002 – Genehmigte Nutzung und KI-Kompetenz

Normative Anforderung

Für jeden Anwendungsfall MÜSSEN Zweck, zulässige Daten, freigegebene Modelle und Werkzeuge, verbotene Handlungen, menschliche Kontrollpflichten und Unterstützungswege festgelegt werden. Nutzende MÜSSEN vor Freischaltung und anschließend risikoorientiert qualifiziert werden.

Begründung

Generative KI kann überzeugend fehlerhafte Ausgaben liefern und Sicherheitsgrenzen über Eingaben oder Werkzeuge umgehen. Wirksame Regeln benötigen anwendungsbezogene Kompetenz.

Umsetzung im Geltungsbereich

Nutzungsbedingungen werden am Zugang sichtbar bereitgestellt. Rollenbezogene Schulungen behandeln Datenklassifikation, eingeschleuste Anweisungen, Ergebnisprüfung, Kennzeichnung, Melde-
wege und Grenzen agentischer Aktionen.

Prüfziel

Prüfen, ob nur genehmigte Anwendungsfälle aktiviert sind und Nutzende die maßgeblichen Grenzen nachweislich verstehen.

Erwartete Nachweise

Nutzungsbedingungen; Schulungsplan; Teilnahme- und Wirksamkeitsnachweise; technische Freigabelisten; Stichproben aus Rollenvergaben.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Einführung; Betrieb; Änderung; KI-Verantwortliche; Fachverantwortliche; Personalentwicklung; Nutzende
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.3, ORP.4; ISO: ISO/IEC 42001:2023 A.6, ISO/IEC 27002:2022 6.3

Quellen

[Q-BSI-001] S. 8–10 und S. 13; [Q-BMI-001] S. 29–30; [Q-EU-001] Art. 4⁶

ABl. L 2024/1689, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 12.07.2024, Art. 9 und 26, <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>, abgerufen am 02.09.2026.

⁶ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 8–10 und S. 13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, PDF-Stand 07.04.2025, S. 29–30, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026. | Europäische Union: Verordnung (EU) 2024/1689 über künstliche Intelligenz, ABl. L 2024/1689, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 12.07.2024, Art. 4, <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>, abgerufen am 02.09.2026.

KI-GOV-003 – Lebenszyklus-Risikosteuerung, Ausnahmen und Überprüfungen

Normative Anforderung

KI-spezifische Risiken MÜSSEN vor Erstnutzung, regelmäßig mindestens jährlich und anlassbezogen nach Modell-, Daten-, Werkzeug-, Schnittstellen- oder Architekturänderungen nach einem festgelegten Verfahren bewertet werden. Geringe Risiken DÜRFEN überwacht akzeptiert werden. Mittlere Risiken DÜRFEN nur befristet, verantwortlich und mit Maßnahmenplan akzeptiert werden. Hohe und sehr hohe Risiken MÜSSEN eine Erstfreigabe oder den Weiterbetrieb bis zur wirksamen Behandlung sperren.

Begründung

Modelle und Wissensbestände ändern Verhalten, Bedrohungsfläche und Ergebnisqualität auch ohne klassische Softwareänderung.

Umsetzung im Geltungsbereich

Der Risikozyklus legt Geltungsbereich und Schutzziele fest, beschreibt Gefährdungen als konkrete Szenarien, schätzt Eintrittshäufigkeit und Schadenshöhe ein, ordnet die Risikokategorie anhand der festgelegten Matrix zu und bestimmt die Behandlung. Nach der Behandlung wird das verbleibende Risiko erneut eingestuft. Risikoregister, Freigaben, Betriebsbeobachtung, Vorfälle und Außerbetriebnahme bleiben miteinander verknüpft.

Prüfziel

Prüfen, ob aktuelle Risikobewertungen alle wesentlichen Änderungen abdecken, die festgelegte Matrix nachvollziehbar anwenden, hohe und sehr hohe Risiken sperren und jede Akzeptanz befugt sowie befristet dokumentieren.

Erwartete Nachweise

Risikoregister; Bewertungsmatrix; Änderungsereignisse; Prüfkalender; Ausnahmegenehmigungen; Restrisikoakzeptanzen; Maßnahmenverfolgung; Freigabe- und Sperrnachweise.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Gesamter-Lebenszyklus; Risikoverantwortliche; KI-Verantwortliche; Informationssicherheitsbeauftragte; Leitung
Orientierende Zuordnung	BSI/IT-Grundschutz: ISMS.1, OPS.1.1.3; ISO: ISO/IEC 27001:2022 6.1, ISO/IEC 42001:2023 6.1, ISO/IEC 23894:2023

Quellen

[Q-BSI-001] S. 8, 10 und 12; [Q-BSI-2003-001] S. 5–7, S. 26–28 und S. 33–35; [Q-BMVG-001] S. 24–25 und S. 45–47; [Q-NIST-001] Govern-, Map-, Measure- und Manage-Aktionen⁷

⁷ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 8, 10 und 12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: BSI-Standard 200-3: Risikomanagement, Version 1.0, Stand Oktober 2017, S. 5–7, S. 26–28 und S. 33–35, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/BSI_Standards/standard_200_3.pdf?__blob=publicationFile&v=2, abgerufen am 03.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung,

9.3 Recht, Datenschutz, Mitbestimmung, Schutzbedarf und Geheimschutzfreigaben

KI-REC-001 – Rechts- und Datenschutzprüfung je Anwendungsfall

Normative Anforderung

Vor Freigabe eines Anwendungsfalls MÜSSEN anwendbare Rechtsgrundlagen, Rollen, Zweckbindung, Datenminimierung, Transparenz, Betroffenenrechte, Löschung, erforderliche Datenschutz-Folgenabschätzung und Beteiligungsrechte dokumentiert und durch zuständige Stellen geprüft werden.

Begründung

Die rechtliche Bewertung hängt von Zweck, Daten, Rolle und Wirkung des konkreten Einsatzes ab und kann nicht aus der lokalen Betriebsform allein abgeleitet werden.

Umsetzung im Geltungsbereich

Eine Anwendbarkeitsmatrix führt KI-Verordnung, Datenschutzrecht, Informationssicherheitsrecht, Mitbestimmung und fachgesetzliche Anforderungen zusammen. Ergebnisse werden als Freigabebedingungen technisch umgesetzt.

Prüfziel

Feststellen, ob jeder freigegebene Anwendungsfall eine aktuelle, nachvollziehbare und von zuständigen Rollen bestätigte Prüfung besitzt.

Erwartete Nachweise

Rechts- und Datenschutzmatrix; Verzeichnis von Verarbeitungstätigkeiten; Datenschutz-Folgenabschätzung oder dokumentierte Nicht-Erforderlichkeit; Beteiligungs- und Freigabenachweise.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Planung; Freigabe; Änderung; Rechtsstelle; Datenschutzbeauftragte; Personalvertretung; Fachverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.5, CON.2; ISO: ISO/IEC 42001:2023 4.2, ISO/IEC 27001:2022 4.2

Quellen

[Q-EU-001] Art. 2–4, 26–27; [Q-BFDI-001] Kap. 1–7; [Q-DSK-001] Auswahl bis Beendigung⁸

K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 24–25 und S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, Stand 26.07.2024, Govern-, Map-, Measure- und Manage-Aktionen, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026.

⁸ Europäische Union: Verordnung (EU) 2024/1689 über künstliche Intelligenz, ABl. L 2024/1689, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 12.07.2024, Art. 2–4, 26–27, <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>, abgerufen am 02.09.2026. | Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit: KI in Behörden – Datenschutz von Anfang an mitdenken, Handreichung für die Bundesverwaltung, Stand 22.12.2025, Kap. 1–7, https://www.bfdi.bund.de/SharedDocs/Downloads/DE/DokumenteBfDI/Dokumente-allg/2025/Handreichung-KI.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des

KI-REC-002 – Schutzbedarf und Geheimschutzfreigabe

Normative Anforderung

Eingaben, Ausgaben, Suchvektoren, Indizes, Protokolle und Modelle MÜSSEN einem Schutzbedarf zugeordnet werden. Für Verschlusssachen oder andere besonders geschützte Inhalte MUSS vor jeder Verarbeitung eine ausdrückliche Zulässigkeits- und Systemfreigabe vorliegen; ohne diese Freigabe ist die Verarbeitung unzulässig.

Begründung

Aus Quelldaten abgeleitete Darstellungen können schutzbedürftige Inhalte bewahren oder eine Rekonstruktion ermöglichen. Ein allgemeiner KI-Zugang darf keine Geheimschutzentscheidung treffen.

Umsetzung im Geltungsbereich

Schutzbedarf und zulässige Verarbeitung werden als technische Richtlinien am kontrollierten KI-Zugang, im Index der lokalen Wissenssuche, in Regeln für Dateiübernahmen und in Werkzeugberechtigungen durchgesetzt. Nicht eindeutig zulässige Inhalte werden abgewiesen.

Prüfziel

Prüfen, ob alle Datenformen erfasst sind und besonders geschützte Inhalte ohne dokumentierte Freigabe zuverlässig blockiert werden.

Erwartete Nachweise

Schutzbedarfsfeststellung; Datenfluss- und Klassifikationsmatrix; Freigaben; technische Richtlinien; negative Verarbeitungstests.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Planung; Nutzung; Änderung; Informationssicherheitsbeauftragte; Geheimschutzbeauftragte; Datenschutzbeauftragte; Datenverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: CON.10, ORP.4; ISO: ISO/IEC 27002:2022 5.12, ISO/IEC 27002:2022 5.13

Quellen

[Q-BMI-001] S. 25–27; [Q-SUEG-001] § 4; [Q-VSA-001] Einstufungs- und Handhabungsregeln; [Q-DSK-003] Kap. 2–5⁹

Bundes und der Länder: Künstliche Intelligenz und Datenschutz, Version 1.0, Stand 06.05.2024, Auswahl bis Beendigung, https://www.datenschutzkonferenz-online.de/media/oh/20240506_DSK_Orientierungshilfe_KI_und_Datenschutz.pdf, abgerufen am 02.09.2026.

⁹ Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, PDF-Stand 07.04.2025, S. 25–27, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026. | Bundesrepublik Deutschland: Sicherheitsüberprüfungsgesetz, § 4 Verschlusssachen, SÜG, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 20.04.1994, § 4, https://www.gesetze-im-internet.de/s_g/_4.html, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat: Allgemeine Verwaltungsvorschrift zum materiellen Geheimschutz, Verschlusssachenanweisung, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 13.03.2023, Einstufungs- und Handhabungsregeln, https://www.verwaltungsvorschriften-im-internet.de/bsvvwbund_13032023_SII554001405.htm, abgerufen am 02.09.2026. | Konferenz der unabhängigen

9.4 Lokale Systemarchitektur und Vertrauensgrenzen

KI-ARC-001 – Explizite Zonen und einziger kontrollierter KI-Zugang

Normative Anforderung

Clientzone, kontrollierter KI-Zugang, KI-Serverzone, Importweg sowie Betriebs- und Nachweisbereich MÜSSEN als Vertrauenszonen beschrieben und technisch getrennt werden. Aus dem Clientnetz DARF nur der kontrollierte HTTPS-Zugang erreichbar sein.

Begründung

Direkte Rohschnittstellen umgehen zentrale Identitäts-, Richtlinien-, Protokollierungs- und Begrenzungsentscheidungen.

Umsetzung im Geltungsbereich

Firewall-, Routing-, Proxy- und Dienstkonfigurationen veröffentlichen nur den Endpunkt des kontrollierten KI-Zugangs. Interne Inferenz-, Verwaltungs-, Messwert-, Diagnose-, Cluster- und Zwischenspeicher-Schnittstellen werden nicht in das normale Netz gebunden.

Prüfziel

Durch Netz- und Porttests nachweisen, dass erlaubte Flüsse funktionieren und sämtliche internen Schnittstellen aus Client- und Fernzugriffsnetzen unerreichbar sind.

Erwartete Nachweise

Aktuelles Zonen- und Datenflussmodell; Firewall- und Proxyregeln; Portinventar; positive und negative Netztests; Konfigurationsauszüge.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Architektur; Einführung; Betrieb; Netzverantwortliche; Systemverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: NET.1.1, NET.3.2; ISO: ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.22

Quellen

[Q-BSI-001] S. 11–12; [Q-BMVG-001] S. 23–26; [Q-ENISA-001] Multilayer framework¹⁰

Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0, Stand Oktober 2025, veröffentlicht am 17.10.2025, Kap. 2–5, https://www.datenschutzkonferenz-online.de/media/oh/DSK_OH_RAG.pdf, abgerufen am 02.09.2026.

¹⁰ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 11–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 23–26, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | European Union Agency for Cybersecurity: Multilayer Framework for Good Cybersecurity Practices for AI, Erstveröffentlichung, Stand 2023, veröffentlicht am 15.11.2023, Multilayer framework, <https://www.enisa.europa.eu/publications/multilayer-framework-for-good-cybersecurity-practices-for-ai>, abgerufen am 02.09.2026.

KI-ARC-002 – Vollständig lokale Datenhaltung ohne ausgehende Internetverbindung

Normative Anforderung

Inferenz, Identitäten, Git, Ablagen, Registrierungen, Modelle, RAG-Daten, Suchvektoren, Chatverläufe, Protokolle, Telemetrie und Sicherungen MÜSSEN lokal betrieben werden. KI-Komponenten DÜRFEN im Standardbetrieb keine ausgehende Internetverbindung besitzen.

Begründung

Unkontrollierter ausgehender Netzwerkverkehr ermöglicht Datenabfluss, Telemetrie, Lieferkettengriffe und unbeabsichtigte Ausweichverbindungen zu Cloud-Diensten außerhalb der festgelegten Systemgrenze.

Umsetzung im Geltungsbereich

Ausgehender Netzwerkverkehr wird technisch standardmäßig verweigert. Aktualisierungen und Artefakte durchlaufen einen getrennten Import-, Schadsoftware-, Signatur-, Prüfsummen- und Freigabeprozess mit lokalen Spiegeln.

Prüfziel

Prüfen, ob alle genannten Datenklassen lokale Speicherorte besitzen und unerlaubte externe Verbindungen technisch sowie durch Beobachtung ausgeschlossen sind.

Erwartete Nachweise

Datenhaltungsregister; Regeln für ausgehenden Netzwerkverkehr; DNS-/Proxyprotokolle; Telemetrie-einstellungen; Importnachweise; negative Verbindungstests.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Architektur; Betrieb; Änderung; Netzverantwortliche; Plattformverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: NET.1.1, OPS.1.1.10; ISO: ISO/IEC 27002:2022 5.14, ISO/IEC 27002:2022 8.20

Quellen

[Q-BSI-001] S. 9–12; [Q-BMI-001] S. 25–28; [Q-NCSC-001] Secure deployment und operation¹¹

¹¹ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 9–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, PDF-Stand 07.04.2025, S. 25–28, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026. | UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development, Version 1.0, Stand November 2023, veröffentlicht am 26.11.2023, Secure deployment und operation, <https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/about-this-document>, abgerufen am 02.09.2026.

9.5 Container-, Inferenz- und API-Sicherheit

KI-CON-001 – Standardmäßig verweigerte Containerkommunikation

Normative Anforderung

Container- und Pod-Kommunikation MUSS standardmäßig verweigert und für dokumentierte Dienstbeziehungen ausdrücklich erlaubt werden. Ein gemeinsames internes Netz DARF nicht als alleinige Sicherheitsgrenze bewertet werden.

Begründung

Kompromittierte Dateiauswerter, Benutzungsoberflächen oder Agentendienste könnten sonst unerlaubt Inferenzdienste, Datenbanken, Verwaltungs- oder Nachweisschnittstellen erreichen.

Umsetzung im Geltungsbereich

Kubernetes-Netzwerkrichtlinien (NetworkPolicies) oder funktional gleichwertige Docker- beziehungsweise Podman-Regeln begrenzen ein- und ausgehenden Netzwerkverkehr je Dienstidentität. Plattformgrenzen werden durch Firewalls des Serverbetriebssystems ergänzt.

Prüfziel

Durch Soll-Ist-Abgleich und negative Verbindungstests nachweisen, dass ausschließlich modellierte Dienstbeziehungen möglich sind.

Erwartete Nachweise

Kommunikationsmatrix; Netzwerkrichtlinien beziehungsweise gleichwertige Regeln; Firewallregeln des Serverbetriebssystems; automatisierte Netztests; Abweichungsliste.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Architektur; Einführung; Betrieb; Plattformverantwortliche; Netzwerkverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: APP.3.4, SYS.1.6; ISO: ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.22

Quellen

[Q-K8S-001] NetworkPolicySpec, ingress und egress; [Q-PODMAN-001] Network management; [Q-BSI-001] S. 11–12¹²

¹² The Kubernetes Authors: Kubernetes API Reference: NetworkPolicy v1, Online-Dokumentation, Abrufstand 02.09.2026, NetworkPolicySpec, ingress und egress, <https://kubernetes.io/docs/reference/kubernetes-api/networking/network-policy-v1/>, abgerufen am 02.09.2026. | Podman Project: podman-network, Online-Dokumentation, Abrufstand 02.09.2026, Network management, <https://docs.podman.io/en/latest/markdown/podman-network.1.html>, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 11–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

KI-CON-002 – Minimale Containerprivilegien und unveränderbare Laufzeit

Normative Anforderung

KI-Dienste MÜSSEN ohne unnötige Privilegien, ohne privilegierten Modus, mit minimalen Linux-Fähigkeiten und nach Möglichkeit ohne privilegierten Systemnutzer (rootless) betrieben werden. Schreibgeschützte Dateisystemanteile und getrennte, eng begrenzte dauerhafte Datenträger MÜSSEN eingesetzt werden, soweit die Funktion dies zulässt.

Begründung

Dateiauswerter und KI-nahe Dienste verarbeiten potenziell schädliche Inhalte. Übermäßige Rechte erhöhen die Auswirkung einer Kompromittierung auf Serverbetriebssystem, Modelle und Daten.

Umsetzung im Geltungsbereich

Sicherheitskontexte, Nutzerkennungen, entzogene Linux-Fähigkeiten, Systemaufruf-Filter (Seccomp) oder gleichwertige Profile, Einbindungen und Datenträger werden als freigegebener Ausgangsstand geprüft. Abweichungen von diesem Stand werden überwacht.

Prüfziel

Prüfen, ob kein produktiver KI-Dienst unbegründete Rechte auf das Serverbetriebssystem, Geräte, den Betriebssystemkern oder Dateisysteme besitzt.

Erwartete Nachweise

Freigegebener Laufzeitausgangsstand; Bereitstellungsmanifeste; effektive Laufzeitkonfiguration; Abweichungsgenehmigungen; Abweichungsberichte.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Einführung; Betrieb; Änderung; Plattformverantwortliche; Systemverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: SYS.1.6, OPS.1.1.2; ISO: ISO/IEC 27002:2022 8.9, ISO/IEC 27002:2022 8.27

Quellen

[Q-DOCKER-001] Rootless mode; [Q-NCSC-001] Secure deployment und operation; [Q-ENISA-001] Infrastruktur- und Komponentenebene¹³

¹³ Docker, Inc.: Rootless mode, Online-Dokumentation, Abrufstand 02.09.2026, Rootless mode, <https://docs.docker.com/engine/security/rootless/>, abgerufen am 02.09.2026. | UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development, Version 1.0, Stand November 2023, veröffentlicht am 26.11.2023, Secure deployment und operation, <https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/about-this-document>, abgerufen am 02.09.2026. | European Union Agency for Cybersecurity: Multilayer Framework for Good Cybersecurity Practices for AI, Erstveröffentlichung, Stand 2023, veröffentlicht am 15.11.2023, Infrastruktur- und Komponentenebene, <https://www.enisa.europa.eu/publications/multilayer-framework-for-good-cybersecurity-practices-for-ai>, abgerufen am 02.09.2026.

KI-API-001 – Zentrale Authentisierung und Autorisierung am KI-Zugang

Normative Anforderung

Jeder Benutzer- und Dienstzugriff auf KI-Funktionen MUSS über HTTPS, eine lokale vertrauenswürdige Identität und serverseitig erzwungene Autorisierung erfolgen. Gemeinsame statische API-Schlüssel DÜRFEN nicht als reguläre Nutzeridentität dienen; Identitäten MÜSSEN einzeln widerrufbar und protokollierbar sein.

Begründung

Einige lokale Inferenzschnittstellen besitzen keine eigene Authentisierung oder schützen mit einem API-Schlüssel nicht sämtliche sensiblen Endpunkte.

Umsetzung im Geltungsbereich

Ein lokaler vorgeschalteter Zugang (Reverse Proxy oder API-Gateway) beendet die Transportverschlüsselung, bindet den lokalen Identitätsdienst über ein freigegebenes Authentisierungsprotokoll an, setzt Rollen und Dienstkonten durch und blockiert direkte Zugriffe auf nachgelagerte Dienste.

Prüfziel

Mit positiven und negativen Identitäts-, Rollen-, Widerrufs- und Direktzugriffstests nachweisen, dass alle Pfade dieselben Regeln erzwingen.

Erwartete Nachweise

Konfiguration des KI-Zugangs und Identitätsdienstes; Zertifikatsnachweise; Rollenmatrix; Widerrufstest; Zugriffsprotokolle; Tests zur Sperre direkter Dienstzugriffe.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Einführung; Betrieb; Identitätsverantwortliche; Verantwortliche für den KI-Zugang; Plattformverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.4, APP.6, CON.1; ISO: ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 5.16, ISO/IEC 27002:2022 8.5

Quellen

[Q-OLLAMA-001] Local access; [Q-VLLM-001] Security und API server; [Q-OPENWEBUI-002] Authentication und API endpoints; [Q-BSI-001] S. 12¹⁴

¹⁴ Ollama: Authentication, Online-Dokumentation, Abrufstand 02.09.2026, Local access, <https://docs.ollama.com/api/authentication>, abgerufen am 02.09.2026. | vLLM Project: Security, Online-Dokumentation, Abrufstand 02.09.2026, Security und API server, <https://docs.vllm.ai/en/stable/usage/security/>, abgerufen am 02.09.2026. | Open WebUI: API Endpoints, Online-Dokumentation, Abrufstand 02.09.2026, Authentication und API endpoints, <https://docs.openwebui.com/reference/api-endpoints/>, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

KI-API-002 – Serverseitige Modell-, Kontext-, Anfrage- und Werkzeuggrenzen

Normative Anforderung

Der kontrollierte KI-Zugang MUSS pro Rolle und Anwendungsfall freigegebene Modelle, maximale Kontext- und Ausgabegrößen, Grenzen der Anfragehäufigkeit und gleichzeitiger Anfragen sowie zulässige Werkzeugfunktionen serverseitig erzwingen. Clientseitige Einstellungen allein sind unzureichend.

Begründung

Manipulierte oder fehlerhaft konfigurierte Clients können sonst nicht freigegebene Modelle, übermäßige Ressourcen oder privilegierte Funktionen anfordern.

Umsetzung im Geltungsbereich

Richtlinien werden zentral versioniert, getestet und protokolliert. Nicht bekannte Modelle, Parameter, Endpunkte und Fähigkeiten werden abgewiesen.

Prüfziel

Versuchen, Grenzen über alternative Clients, manipulierte Parameter und direkte Endpunkte zu umgehen; jeder Versuch muss verhindert und nachvollziehbar protokolliert werden.

Erwartete Nachweise

Richtlinien des KI-Zugangs; Modellfreigabeliste; Grenzwertkatalog; negative Umgehungstests; Nachweise zur Anfragebegrenzung und Alarmierung.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Einführung; Betrieb; Änderung; Verantwortliche für den KI-Zugang; KI-Verantwortliche; Fachverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: APP.6, DER.1; ISO: ISO/IEC 27002:2022 8.26, ISO/IEC 27002:2022 8.28

Quellen

[Q-BSI-001] S. 11–16; [Q-VLLM-001] Security und API server; [Q-OWASP-001] übermäßige Handlungsfreiheit und Ressourcenverbrauch¹⁵

¹⁵ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 11–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | vLLM Project: Security, Online-Dokumentation, Abrufstand 02.09.2026, Security und API server, <https://docs.vllm.ai/en/stable/usage/security/>, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, übermäßige Handlungsfreiheit und Ressourcenverbrauch, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026.

9.6 Modellbeschaffung, Herkunftsnachweis, Integrität und Austausch

KI-MOD-001 – Kontrollierter Modellimport und Herkunftsnachweis

Normative Anforderung

Jedes Modell MUSS aus einer freigegebenen Quelle über einen kontrollierten Offline-Import übernommen werden. Herkunft, Lizenz, Modellkarte, Format, Version, kryptografische Prüfsumme, verfügbare Signatur, Prüfergebnisse und Freigabeentscheidung MÜSSEN dokumentiert werden; unsichere serialisierte Formate DÜRFEN nicht ungeprüft geladen werden.

Begründung

Modelle sind ausführbare beziehungsweise interpretierte Lieferkettenartefakte. Manipulierte Gewichte oder Formate können Fehlverhalten, Schadcode oder Datenabfluss ermöglichen.

Umsetzung im Geltungsbereich

Ein Vier-Augen-Importprozess lädt außerhalb der KI-Zone, prüft kryptografische Prüfsummen, Signaturen, Dateiformat, Schadsoftware und Herkunft und veröffentlicht nur freigegebene, unveränderbare Artefakte in einer lokalen Modellregistrierung.

Prüfziel

Für jedes aktive Modell die vollständige Kette von der öffentlichen Herkunft bis zur tatsächlich geladenen kryptografischen Prüfsumme nachvollziehen und manipulierte Testartefakte abweisen.

Erwartete Nachweise

Modellakte; Prüfsummen- und Signaturnachweise; Lizenzprüfung; Importprotokoll; Prüfergebnis; lokale Registrierungsdaten; negativer Manipulationstest.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Beschaffung; Import; Freigabe; Modellverantwortliche; Informationssicherheitsbeauftragte; Beschaffung
Orientierende Zuordnung	BSI/IT-Grundschutz: OPS.1.1.10, OPS.1.1.6; ISO: ISO/IEC 27002:2022 5.21, ISO/IEC 27002:2022 8.19

Quellen

[Q-BSI-001] S. 9–10; [Q-NCSC-001] Secure development und deployment; [Q-OWASP-001] Lieferkettenrisiken¹⁶

¹⁶ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 9–10, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development, Version 1.0, Stand November 2023, veröffentlicht am 26.11.2023, Secure development und deployment, <https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/about-this-document>, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, Lieferkettenrisiken, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026.

KI-MOD-002 – Versionierte Modellfreigabe und Rückkehr zur Vorversion

Normative Anforderung

Modellfreigaben MÜSSEN eine unveränderbare Modellprüfsumme, Laufzeitversion, Komprimierungsstufe (Quantisierung), Systemanweisungen, Sicherheitsparameter, Bewertungsstand und genehmigte Anwendungsfälle binden. Austausch, Rücknahme und Rückkehr zur freigegebenen Vorversion MÜSSEN ohne Veränderung von Fachwissen im Modell möglich und erprobt sein.

Begründung

Gleich benannte Modelle oder geänderte Laufzeiten können abweichendes Verhalten zeigen. Die Trennung des Fachwissens über RAG ermöglicht kontrollierten Austausch.

Umsetzung im Geltungsbereich

Freigabemanifeste verwenden unveränderbare Kennungen. Vorherige geprüfte Kombinationen bleiben innerhalb der Aufbewahrungsfrist lokal verfügbar; Abhängigkeiten und RAG-Kompatibilität werden geprüft.

Prüfziel

Eine freigegebene Version eindeutig reproduzieren, einen Modellwechsel durch Wiederholungsprüfungen bewerten und auf eine vorherige freigegebene Kombination zurückkehren.

Erwartete Nachweise

Freigabemanifest; Modell- und Laufzeitprüfsummen; Bewertungsbericht; Änderungsfreigabe; dokumentierter Rückkehrtest; RAG-Kompatibilitätsnachweis.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Freigabe; Änderung; Betrieb; Modellverantwortliche; Testverantwortliche; Änderungsverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: OPS.1.1.3, OPS.1.1.6; ISO: ISO/IEC 42001:2023 A.6, ISO/IEC 5338:2023

Quellen

[Q-BSI-001] S. 9–12; [Q-BMVG-001] S. 25–32; [Q-ISO-5338] öffentliche Metadaten zum KI-Systemlebenszyklus¹⁷

¹⁷ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 9–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 25–32, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — AI system life cycle processes, ISO/IEC 5338:2023, Stand ISO-Metadaten, Ausgabe 2023-12, veröffentlicht am 01.12.2023, öffentliche Metadaten zum KI-Systemlebenszyklus, <https://www.iso.org/standard/81118.html>, abgerufen am 02.09.2026.

9.7 Ausdrückliches Trainings- und Feinabstimmungsverbot

KI-TRN-001 – Keine Änderung von Modellgewichten

Normative Anforderung

Vortraining und Verfahren zur Anpassung vortrainierter Modellgewichte wie Fine-Tuning, LoRA, PEFT oder RLHF, kontinuierliches oder selbsttätiges Lernen sowie Training aus Chats, Dateiübernahmen, RAG-Dokumenten oder Nutzereingaben DÜRFEN innerhalb dieses Geltungsbereichs nicht stattfinden. Produktive Modellgewichte MÜSSEN unveränderbar sein.

Begründung

Training eröffnet eigenständige Risiken für Datenrecht, Datenqualität, Modellintegrität, Reproduzierbarkeit und Freigabe. Basismodelle bleiben austauschbar; Fachwissen verbleibt außerhalb der Gewichte.

Umsetzung im Geltungsbereich

Trainingssoftware, Schreibpfade auf Modellgewichte und lernende Rückkopplungen werden nicht bereitgestellt. Die Erzeugung von Suchvektoren, die RAG-Indexierung, Systemanweisungen und vorübergehender Gesprächskontext werden technisch und dokumentarisch klar abgegrenzt.

Prüfziel

Prüfen, dass Architektur, Pakete, Rechte, Jobs und Speicherpfade keine Gewichtsänderung erlauben und Nutzungsdaten nicht als Trainingsdaten exportiert werden.

Erwartete Nachweise

Software- und Jobinventar; schreibgeschützte Modellablage; Dateiintegritätsmessung; Datenflussprüfung; negative Trainingstests; Freigaberegeln.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Gesamter-Lebenszyklus; KI-Verantwortliche; Plattformverantwortliche; Datenverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: APP.6, OPS.1.1.3; ISO: ISO/IEC 42001:2023 A.6, ISO/IEC 5338:2023

Quellen

[Q-BSI-001] S. 5 zur Abgrenzung von Modellentwicklung und Fine-Tuning; [Q-BMVG-001] S. 25–32 zum kontrollierten Lebenszyklus; [Q-ISO-5338] öffentliche Lebenszyklusmetadaten¹⁸

¹⁸ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 5 zur Abgrenzung von Modellentwicklung und Fine-Tuning, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 25–32 zum kontrollierten Lebenszyklus, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — AI system life cycle processes, ISO/IEC 5338:2023, Stand ISO-Metadaten, Ausgabe 2023-12,

9.8 Sicherheit der lokalen Wissenssuche, Suchvektoren und Dateiübernahmen

KI-RAG-001 – Kontrollierte Aufnahme und isolierte Dokumentenaufbereitung

Normative Anforderung

RAG-Dokumente und Dateiübernahmen MÜSSEN vor Verarbeitung auf zulässigen Dateityp, Größe, Schadsoftware und aktive Inhalte geprüft werden. Dateiauswertung, Konvertierung und Textextraktion MÜSSEN isoliert mit minimalen Rechten, ohne ausgehende Internetverbindung und mit begrenzten Ressourcen arbeiten.

Begründung

Dokumente sind nicht als Steueranweisung vertrauenswürdig. Sie können Schwachstellen der Dateiauswertung, aktive Inhalte, Ressourcenangriffe oder eingeschleuste Anweisungen enthalten.

Umsetzung im Geltungsbereich

Eine Quarantäne nimmt Dateien entgegen, prüft Signatur und tatsächlichen Typ, untersucht sie auf Schadsoftware und übergibt nur zulässige Inhalte an kurzlebige isolierte Dateiauswerter. Fehlerhafte oder mehrdeutige Dateien werden abgewiesen.

Prüfziel

Mit präparierten Dateien prüfen, ob Typumgehung, aktive Inhalte, Schadsoftware, Abstürze der Dateiauswertung und Ressourcenüberschreitungen sicher behandelt werden.

Erwartete Nachweise

Richtlinie für Dateiübernahmen; Sicherheitsprofil der Dateiauswerter; Schadsoftware- und Typprüfprotokolle; Ressourcengrenzen; negative Testdateisammlungen; Quarantäne- und Löschprotokolle.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Aufnahme; Betrieb; RAG-Verantwortliche; Plattformverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: APP.6, SYS.1.6; ISO: ISO/IEC 27002:2022 8.7, ISO/IEC 27002:2022 8.26

Quellen

[Q-DSK-003] Kap. 2–5; [Q-DSK-002] Kap. 2–6; [Q-OWASP-001] Prompt Injection und Ressourcenverbrauch¹⁹

veröffentlicht am 01.12.2023, öffentliche Lebenszyklusmetadaten, <https://www.iso.org/standard/81118.html>, abgerufen am 02.09.2026.

¹⁹ Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0, Stand Oktober 2025, veröffentlicht am 17.10.2025, Kap. 2–5, https://www.datenschutzkonferenz-online.de/media/oh/DSK_OH_RAG.pdf, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu empfohlenen technischen und organisatorischen Maßnahmen bei der Entwicklung und beim Betrieb von KI-Systemen, Version 1.0, Stand Juni 2025, veröffentlicht am 17.06.2025, Kap. 2–6, https://www.datenschutzkonferenz-online.de/media/oh/DSK-OH_KI-Systeme.pdf, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, Prompt Injection und Ressourcenverbrauch, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026.

KI-RAG-002 – Durchgängige Berechtigungsprüfung und Indextrennung

Normative Anforderung

Vor Aufnahme eines Dokuments und bei jeder Abfrage MUSS die Berechtigung anhand einer maßgeblichen lokalen Quelle geprüft werden. Zugriffsentscheidungen DÜRFEN weder Systemanweisungen noch dem Sprachmodell überlassen werden. Index, Metadaten, Suche, Zwischenspeicher und Ausgabe MÜSSEN dieselbe Berechtigungstrennung wahren.

Begründung

Ein gemeinsamer Suchindex oder nur durch Anweisungen gesteuerte Filter können geschützte Textausschnitte über die inhaltliche Ähnlichkeitssuche, Zwischenspeicher oder Modellausgaben offenlegen.

Umsetzung im Geltungsbereich

Dokumente tragen Herkunft, Eigentümer, Schutzbedarf und Metadaten zu Zugriffsrechten. Die Suchschicht filtert vor der Suche serverseitig mit der aktuellen Nutzeridentität; Änderungen und Widerrufe werden zeitnah übernommen.

Prüfziel

Mit berechtigten und unberechtigten Testidentitäten belegen, dass Aufnahme, Suche, direkte Objektanfrage, Zwischenspeicher und generierte Antwort keine Grenze der Zugriffsregeln überschreiten.

Erwartete Nachweise

Zugriffsregeln und Zuordnung der Identitäten; Indexschema; Filterkonfiguration; nachgewiesene Übernahmezeit von Berechtigungswiderrufen; positive und negative Berechtigungstests; Tests der Zwischenspeicher.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Aufnahme; Abfrage; Änderung; Datenverantwortliche; RAG-Verantwortliche; Identitätsverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.4, APP.6; ISO: ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 8.3

Quellen

[Q-DSK-003] Kap. 2–5; [Q-BSI-001] S. 11–12; [Q-BFDI-001] Kap. 3–7²⁰

²⁰ Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0, Stand Oktober 2025, veröffentlicht am 17.10.2025, Kap. 2–5, https://www.datenschutzkonferenz-online.de/media/oh/DSK_OH_RAG.pdf, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 11–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit: KI in Behörden – Datenschutz von Anfang an mitdenken, Handreichung für die Bundesverwaltung, Stand 22.12.2025, Kap. 3–7, https://www.bfdi.bund.de/SharedDocs/Downloads/DE/DokumenteBfDI/Dokumente-allg/2025/Handreichung-KI.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

KI-RAG-003 – Schutz, Nachvollziehbarkeit und vollständige Löschung abgeleiteter Daten

Normative Anforderung

Suchvektoren, Textabschnitte, Indizes, Daten zur Neusortierung von Suchtreffern und Zwischenspeicher MÜSSEN mindestens wie die Quelldaten geschützt werden. Herkunft und konkrete Fundstellen MÜSSEN bis zur Ausgabe nachvollziehbar bleiben. Löschung MUSS Quelldatei, Extrakte, Index, Suchvektoren, Zwischenspeicher und den geregelten Ablauf in Sicherungsketten erfassen.

Begründung

Abgeleitete Daten können Inhalte, Personenbezug und Schutzbedarf der Quelle bewahren. Unvollständige Löschung oder ein fehlender Herkunftsnachweis verhindert Betroffenenrechte und fachliche Prüfung.

Umsetzung im Geltungsbereich

Stabile Kennungen für Dokumente und Textabschnitte verbinden Quelle, Version, Zugriffsregel und Aufbewahrung. Ein Löschauftrag erzeugt überprüfbare Löschemarkierungen, entfernt Onlinekopien und steuert das Auslaufen aus Sicherungen.

Prüfziel

Für eine Testquelle Herkunft bis zur Antwort nachweisen und anschließend die Nichtauffindbarkeit in sämtlichen Onlineebenen sowie geregelte Sicherungsbehandlung bestätigen.

Erwartete Nachweise

Datenkatalog; Herkunftsmetadaten; Quellennachweise in Ausgaben; Aufbewahrungsplan; Löschprotokoll; Nachtest von Suche und Zwischenspeichern; Sicherungskonzept.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Aufnahme; Nutzung; Löschung; Datenverantwortliche; RAG-Verantwortliche; Backup-Verantwortliche; Datenschutzbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: CON.6, CON.3; ISO: ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 8.13, ISO/IEC 5259-1:2024

Quellen

[Q-DSK-003] Kap. 2–5; [Q-DSK-002] Kap. 2–6; [Q-BFDI-001] Kap. 4–7²¹

²¹ Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0, Stand Oktober 2025, veröffentlicht am 17.10.2025, Kap. 2–5, https://www.datenschutzkonferenz-online.de/media/oh/DSK_OH_RAG.pdf, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu empfohlenen technischen und organisatorischen Maßnahmen bei der Entwicklung und beim Betrieb von KI-Systemen, Version 1.0, Stand Juni 2025, veröffentlicht am 17.06.2025, Kap. 2–6, https://www.datenschutzkonferenz-online.de/media/oh/DSK-OH_KI-Systeme.pdf, abgerufen am 02.09.2026. | Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit: KI in Behörden – Datenschutz von Anfang an mitdenken, Handreichung für die Bundesverwaltung, Stand 22.12.2025, Kap. 4–7, https://www.bfdi.bund.de/SharedDocs/Downloads/DE/DokumenteBfDI/Dokumente-allg/2025/Handreichung-KI.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

KI-RAG-004 – Sitzungsbezogene bedarfsgesteuerte Dateiübernahmen

Normative Anforderung

Bedarfsgesteuerte Dateiübernahmen MÜSSEN standardmäßig sitzungsbezogen, zweckgebunden und zeitlich begrenzt verarbeitet werden. Eine dauerhafte Ablage oder Aufnahme in einen dauerhaften RAG-Bestand DARF nur nach ausdrücklicher Genehmigung, Metadatenvergabe und Berechtigungsprüfung erfolgen.

Begründung

Beiläufige Dateiübernahmen können unbemerkt zu dauerhaften Wissens- oder Protokollbeständen werden und Zweckbindung, Löschung sowie Zugriffsschutz unterlaufen.

Umsetzung im Geltungsbereich

Vorübergehende Speicher verwenden eindeutige Sitzungs- und Nutzerbindung, kurze Aufbewahrung, keine globale Suche und einen nachweislich vollständigen Löschlauf. Benutzungsoberfläche und Programmierschnittstelle zeigen die Speicherwirkung vor der Dateiübernahme an.

Prüfziel

Nach Sitzungsende prüfen, dass übertragene Datei, Auszüge, Suchvektoren und Zwischenspeicher nicht mehr zugreifbar sind und keine Aufnahme in dauerhafte Indizes erfolgte.

Erwartete Nachweise

Anzeige der Speicherwirkung; Aufbewahrungskonfiguration; Sitzungsbindung; Protokolle automatisierter Löschaufträge; negative Suchtests; Genehmigung für dauerhafte Ausnahmen.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Nutzung; Löschung; Nutzende; RAG-Verantwortliche; Datenschutzbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: CON.6, APP.6; ISO: ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 8.12

Quellen

[Q-DSK-003] Kap. 2–5; [Q-BMI-001] S. 25–29²²

²² Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0, Stand Oktober 2025, veröffentlicht am 17.10.2025, Kap. 2–5, https://www.datenschutzkonferenz-online.de/media/oh/DSK_OH_RAG.pdf, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, PDF-Stand 07.04.2025, S. 25–29, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026.

9.9 Identitäten, Rollen, technische Konten und Geheimnisse

KI-IAM-001 – Minimalrechte und Umgang mit Zugangsdaten und Geheimnissen für KI-Dienste

Normative Anforderung

Nutzer-, Dienst- und Administrationsidentitäten MÜSSEN getrennt, minimal berechtigt, einzeln widerrufbar und einer verantwortlichen Stelle zugeordnet sein. Geheimnisse DÜRFEN nicht in Eingaben, Projektdateien, Containerabbildern, Modelldateien, Chatverläufen oder Protokollen gespeichert werden.

Begründung

Agentische Werkzeuge und KI-Dienste verbinden Dateisysteme, APIs und Entwicklungswerkzeuge; ein gemeinsames Konto vergrößert Wirkung und erschwert Zurechnung.

Umsetzung im Geltungsbereich

Lokaler Identitätsdienst, kurzlebige Anmeldedaten, verwaltete lokale Geheimnisablage, dienstbezogene Rollen, Mehrfaktorauthentisierung für privilegierte Zugriffe und regelmäßige erneute Berechtigungsprüfungen werden eingesetzt. Protokollfilter verdecken Geheimnismuster.

Prüfziel

Prüfen, ob effektive Rechte dem genehmigten Zweck entsprechen, Widerruf wirksam ist und Geheimnisse weder in typischen Eingabe- noch Ausgabepfaden erscheinen.

Erwartete Nachweise

Rollen- und Kontenregister; erneute Berechtigungsprüfung; Konfiguration der Geheimnisablage; Widerrufstest; Suchlauf in Codeablagen und Protokollen; Administrationsnachweise.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Einführung; Betrieb; Änderung; Identitätsverantwortliche; Plattformverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.4, CON.7; ISO: ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 5.16, ISO/IEC 27002:2022 8.2

Quellen

[Q-BSI-001] S. 8–13; [Q-BMI-001] S. 25–29; [Q-DSK-002] Kap. 2–6²³

²³ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 8–13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, PDF-Stand 07.04.2025, S. 25–29, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu empfohlenen technischen und organisatorischen Maßnahmen bei der Entwicklung und beim Betrieb von KI-Systemen, Version 1.0, Stand Juni 2025, veröffentlicht am 17.06.2025, Kap. 2–6, https://www.datenschutzkonferenz-online.de/media/oh/DSK-OH_KI-Systeme.pdf, abgerufen am 02.09.2026.

9.10 Chat-Oberflächen und agentische Clientanwendungen

KI-AGT-001 – Minimale lokale Arbeitsbereichs- und Dateirechte

Normative Anforderung

Chat-Oberflächen und agentische Clients MÜSSEN auf genehmigte lokale Arbeitsbereiche und die minimal erforderlichen Lese- beziehungsweise Schreibrechte begrenzt werden. Pauschale Administrator-, Benutzerprofil-, Laufwerks- oder Rechte auf Codeablagen DÜRFEN nicht erteilt werden.

Begründung

Agentische Anwendungen können Modellentscheidungen in reale Datei- und Quellcodeänderungen übersetzen. Breite Rechte verwandeln Fehlanweisungen oder eingeschleuste Anweisungen in unmittelbare Schäden.

Umsetzung im Geltungsbereich

Arbeitsbereichsprofile trennen Lesen, Schreiben, Ausführen und Netz. Betriebssystemrechte, eine abgeschottete Ausführungsumgebung oder gleichwertige Kontrollen verhindern Zugriffe außerhalb des ausgewählten Projekts.

Prüfziel

Mit Testdateien innerhalb und außerhalb des Arbeitsbereichs nachweisen, dass jede nicht genehmigte Lese-, Schreib- und Ausführungsoperation scheitert.

Erwartete Nachweise

Clientrichtlinie; wirksame Dateirechte; Profil der abgeschotteten Ausführungsumgebung; Rollenfreigabe; negative Pfad- und Privilegiertests.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Einführung; Nutzung; Clientverantwortliche; Fachverantwortliche; Nutzende
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.4, APP.6; ISO: ISO/IEC 27002:2022 8.2, ISO/IEC 27002:2022 8.18

Quellen

[Q-BSI-001] S. 12–16; [Q-CLINE-001] Provider- und Endpunktconfiguration; [Q-OPENCODE-001] lokale Modelle und Provider²⁴

²⁴ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 12–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Cline Bot Inc.: Cline Model Providers, Commit 0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710, Commit vom 12.05.2026, Provider- und Endpunktconfiguration, <https://github.com/cline/cline/blob/0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710/docs/sdk/model-providers.mdx>, abgerufen am 02.09.2026. | Anomaly Innovations Inc.: OpenCode Models, Version 2, Online-Dokumentation, Abrufstand 02.09.2026, lokale Modelle und Provider, <https://opencode.ai/v2/docs/models>, abgerufen am 02.09.2026.

KI-AGT-002 – Lokale und freigegebene Modellendpunkte

Normative Anforderung

Chat- und Agentenclients MÜSSEN ausschließlich auf freigegebene lokale HTTPS-Endpunkte festgelegt werden. Nutzende DÜRFEN keine beliebigen Anbieter, Basisadressen oder Modelle hinzufügen; Telemetrie, automatische Anmeldung und automatische Ausweichverbindungen zu Cloud-Diensten MÜSSEN deaktiviert sein.

Begründung

Kompatible Endpunktconfigurationen erleichtern den unbeabsichtigten Wechsel zu externen Diensten und umgehen zentrale Modellfreigaben.

Umsetzung im Geltungsbereich

Clientkonfigurationen werden verwaltet, signiert oder gegen einen freigegebenen Ausgangsstand geprüft. Namensauflösung und Regeln für ausgehenden Netzwerkverkehr bilden eine zweite technische Sperre.

Prüfziel

Manipulierte Clientkonfigurationen und alternative Anbieter müssen blockiert oder erkannt werden; der wirksame Endpunkt ist serverseitig und im Netzprotokoll nachweisbar.

Erwartete Nachweise

Freigegebener Clientausgangsstand; Anbieterfreigabeliste; Konfigurationsschutz; Protokolle zu ausgehendem Netzwerkverkehr und DNS; negative Anbieter- und Ausweichbindungstests.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Einführung; Betrieb; Clientverantwortliche; Netzverantwortliche; KI-Verantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: APP.6, NET.1.1; ISO: ISO/IEC 27002:2022 8.19, ISO/IEC 27002:2022 8.20

Quellen

[Q-OPENWEBUI-001] OpenAI-kompatible Anbindung; [Q-CLINE-001] OpenAI-Compatible Providers; [Q-OPENCODE-001] Local models; [Q-LLAMACPP-001] llama-server-Verweise²⁵

²⁵ Open WebUI: Starting with OpenAI-compatible providers, Online-Dokumentation, Abrufstand 02.09.2026, OpenAI-kompatible Anbindung, <https://docs.openwebui.com/getting-started/quick-start/connect-a-provider/starting-with-openai-compatible/>, abgerufen am 02.09.2026. | Cline Bot Inc.: Cline Model Providers, Commit 0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710, Commit vom 12.05.2026, OpenAI-Compatible Providers, <https://github.com/cline/cline/blob/0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710/docs/sdk/model-providers.mdx>, abgerufen am 02.09.2026. | Anomaly Innovations Inc.: OpenCode Models, Version 2, Online-Dokumentation, Abrufstand 02.09.2026, Local models, <https://opencode.ai/v2/docs/models>, abgerufen am 02.09.2026. | ggml-org: llama.cpp, Commit ccc8fd2baa64ab26c7210b02765d3604069ec7ee, Stand README-Stand 23.08.2026, llama-server-Verweise, <https://github.com/ggml-org/llama.cpp/tree/ccc8fd2baa64ab26c7210b02765d3604069ec7ee>, abgerufen am 02.09.2026.

9.11 Eingeschleuste Anweisungen, Datenabfluss und unsichere Modellausgaben

KI-PMT-001 – Nicht vertrauenswürdige Inhalte und eingeschleuste Anweisungen

Normative Anforderung

Inhalte aus Dokumenten, Quellcode, Webseiten, Werkzeugausgaben und RAG-Treffern MÜSSEN als nicht vertrauenswürdige Daten behandelt und von Systemanweisungen getrennt werden. Sie DÜRFEN keine Berechtigungen erweitern, Sicherheitsrichtlinien verändern oder selbstständig Werkzeugaktionen auslösen.

Begründung

Sprachmodelle unterscheiden Anweisungen und Daten nicht zuverlässig. Indirekt eingeschleuste Anweisungen können über vertrauenswürdige erscheinende Quellen Aktionen oder Datenabfluss anstoßen.

Umsetzung im Geltungsbereich

Vertrauensmarkierungen, Kontexttrennung, Rangfolge von Anweisungen, Werkzeugrichtlinie, Ausgabeprüfung und Bestätigungssperren wirken gemeinsam. Quellen mit erkannten Manipulationsmustern werden isoliert oder verworfen.

Prüfziel

Mit dokumentierten direkten und indirekten Angriffseingaben prüfen, dass Richtlinien, Berechtigungen, Geheimnisse und Werkzeuggrenzen nicht umgangen werden.

Erwartete Nachweise

Sammlung von Angriffsfällen; Tests mit eingeschleusten Anweisungen; Richtlinienkonfiguration; Angriffsergebnisse; Block- und Alarmprotokolle; akzeptierte Restgrenzen.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Entwurf; Test; Nutzung; Betrieb; KI-Verantwortliche; RAG-Verantwortliche; Testverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: APP.6, DER.1; ISO: ISO/IEC 27002:2022 8.26, ISO/IEC 27002:2022 8.28

Quellen

[Q-BSI-001] S. 11–16; [Q-OWASP-001] Prompt Injection; [Q-NIST-002] adversariale Angriffe und Abhilfen²⁶

²⁶ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 11–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, Prompt Injection, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations, NIST AI 100-2 E2025, Stand Finalfassung 2025, veröffentlicht am 24.03.2025, adversariale Angriffe und Abhilfen, <https://csrc.nist.gov/pubs/ai/100/2/e2025/final>, abgerufen am 02.09.2026.

KI-OUT-001 – Prüfung, Kennzeichnung und menschliche Freigabe von Ausgaben

Normative Anforderung

KI-Ausgaben MÜSSEN als potenziell unzutreffend und nicht vertrauenswürdig behandelt, anwendungsbezogen geprüft und vor sicherheitsrelevanter, rechtlicher oder fachlich wesentlicher Wirkung durch eine befugte Person bestätigt werden. KI-Nutzung und Quellen MÜSSEN entsprechend Zweck und Rechtslage nachvollziehbar gekennzeichnet werden.

Begründung

Plausibel formulierte Fehlantworten, unsicherer Code oder eingebettete Anweisungen können automatisiert weiterverarbeitet und dadurch wirksam werden.

Umsetzung im Geltungsbereich

Struktur-, Typ-, Richtlinien- und Sicherheitsprüfungen begrenzen maschinelle Weiterverarbeitung. Hochwirksame Entscheidungen und Änderungen besitzen ein echtes menschliches Stopprecht und eine nachvollziehbare Freigabe.

Prüfziel

Fehlerhafte, manipulative und formal ungültige Ausgaben einspeisen und nachweisen, dass keine unkontrollierte Folgewirkung eintritt.

Erwartete Nachweise

Prüfregeln; Prüf- und Freigabeprotokolle; Kennzeichnungsvorgaben; Sammlung fehlerhafter Testausgaben; negative Weiterverarbeitungstests.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Nutzung; Freigabe; Betrieb; Nutzende; Fachverantwortliche; Testverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: APP.6, OPS.1.1.6; ISO: ISO/IEC 42001:2023 A.8, ISO/IEC 25059:2023

Quellen

[Q-BMI-001] S. 29–30; [Q-BSI-001] S. 9 und S. 12–16; [Q-BMVG-001] S. 29–32²⁷

²⁷ Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, PDF-Stand 07.04.2025, S. 29–30, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 9 und S. 12–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 29–32, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026.

9.12 Werkzeugnutzung, Dateizugriff und Befehlsausführung

KI-TOL-001 – Getrennte Werkzeugfunktionen und Bestätigung kritischer Aktionen

Normative Anforderung

Lesen, Schreiben, Befehlsausführung und Netzwerkzugriff MÜSSEN als getrennte, standardmäßig deaktivierte Fähigkeiten freigegeben werden. Sicherheitskritische, destruktive, privilegierte oder externe Aktionen MÜSSEN vor Ausführung eine verständliche, konkrete Bestätigung einer befugten Person erfordern.

Begründung

Eine pauschale Agentenfreigabe kann Modellfehler oder manipulierte Inhalte unmittelbar in irreversible Systemänderungen übersetzen.

Umsetzung im Geltungsbereich

Eine server- oder clientseitig erzwungene Werkzeugrichtlinie bindet Fähigkeiten an Rolle, Arbeitsbereich und Anwendungsfall. Bestätigungsdialoge zeigen den genauen Befehl, das Ziel, die Auswirkung und das Datenziel; Sammelfreigaben sind unzulässig.

Prüfziel

Prüfen, ob jede Fähigkeitsgrenze unabhängig wirkt und kritische Testaktionen ohne konkrete Bestätigung nicht ausgeführt werden.

Erwartete Nachweise

Werkzeugrichtlinie; Rollenmatrix; Bestätigungsprotokolle; Testbefehle; negative Rechte- und Umgebungstests.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Entwurf; Einführung; Nutzung; Werkzeugverantwortliche; Clientverantwortliche; Nutzende
Orientierende Zuordnung	BSI/IT-Grundschutz: ORP.4, APP.6; ISO: ISO/IEC 27002:2022 8.2, ISO/IEC 27002:2022 8.18

Quellen

[Q-BSI-001] S. 12–16; [Q-OWASP-001] übermäßige Handlungsfreiheit und unsichere Ausgabe; [Q-NIST-001] Manage- und Measure-Aktionen²⁸

²⁸ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 12–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, übermäßige Handlungsfreiheit und unsichere Ausgabe, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, Stand 26.07.2024, Manage- und Measure-Aktionen, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026.

KI-TOL-002 – Kontrollierte Erweiterungen, MCP-Server und Werkzeugprotokollierung

Normative Anforderung

Erweiterungen, MCP-Server, Werkzeuge und Paketquellen MÜSSEN inventarisiert, lokal bezogen, versionsfixiert, geprüft und ausdrücklich freigegeben werden. Werkzeugaufrufe MÜSSEN mit Identität, Zweck, Parametern, Ziel, Ergebnisstatus und Bestätigungsentscheidung lokal nachvollziehbar protokolliert werden, ohne unnötige Inhalts- oder Geheimnisdaten zu speichern.

Begründung

Erweiterungen bilden eine dynamische Lieferkette und können zusätzliche Rechte oder Wege für ausgehenden Netzwerkverkehr einführen. Ohne Aufrufprotokolle bleiben reale Agentenwirkungen unklar.

Umsetzung im Geltungsbereich

Zulässigkeitslisten, lokale Registrierungen, kryptografische Prüfsummen und Signaturen begrenzen die Lieferkette. Die Protokollierung trennt technische Metadaten von schutzbedürftigen Inhalten und schützt vor nachträglicher Veränderung.

Prüfziel

Unfreigegebene Erweiterungen und Versionen müssen blockiert werden; für genehmigte Testaufrufe muss eine vollständige, datensparsame Nachweiskette entstehen.

Erwartete Nachweise

Erweiterungsinventar; Freigabe- und Importnachweise; kryptografische Prüfsummen; lokale Registrierungen; Werkzeugprüfprotokolle; Manipulationsschutz; negative Installationstests.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Beschaffung; Einführung; Nutzung; Betrieb; Werkzeugverantwortliche; Informationssicherheitsbeauftragte; Protokollierungsverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: OPS.1.1.10, OPS.1.1.5; ISO: ISO/IEC 27002:2022 5.21, ISO/IEC 27002:2022 8.15

Quellen

[Q-BSI-001] S. 10–13; [Q-NCSC-001] Secure development, deployment und operation; [Q-OWASP-001] Lieferkettenrisiken²⁹

²⁹ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 10–13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development, Version 1.0, Stand November 2023, veröffentlicht am 26.11.2023, Secure development, deployment und operation, <https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/about-this-document>, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, Lieferkettenrisiken, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026.

9.13 Gezielte Angriffe, Modellmissbrauch und Ressourcenerschöpfung

KI-THR-001 – KI-spezifisches Bedrohungsmodell

Normative Anforderung

Für jeden Anwendungsfall MUSS ein aktuelles Bedrohungsmodell Eingabe-, Modell-, Daten-, RAG-, Werkzeug-, Client-, Schnittstellen- und Lieferkettenpfade betrachten. Mindestens eingeschleuste Anweisungen, gezielte Manipulation von Modellen, Daten oder Wissensquellen, Umgehung von Schutzmechanismen, Datenrekonstruktion, Modellmissbrauch, unsichere Ausgaben, Rechteauserweiterung und Datenabfluss MÜSSEN bewertet werden.

Begründung

Klassische Systemmodelle erfassen die nicht vollständig vorhersagbare Verarbeitung nicht vertrauenswürdiger Inhalte und die Handlungsketten agentischer Systeme nicht vollständig.

Umsetzung im Geltungsbereich

Datenflussdiagramme markieren Vertrauensgrenzen, Autoren, Veränderungsmöglichkeiten, Aktionen und schutzbedürftige Werte. Angriffstechniken werden mit vorbeugenden, erkennenden und reaktiven Kontrollen verknüpft.

Prüfziel

Prüfen, ob jeder real mögliche Daten- und Aktionspfad modelliert, mit Szenarien getestet und einer verantworteten Behandlung zugeordnet ist.

Erwartete Nachweise

Bedrohungsmodell; Datenflussdiagramm; Angriffsszenarien; Kontrollzuordnung; Testergebnisse; akzeptierte Restrisiken.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Planung; Test; Änderung; Betrieb; Informationssicherheitsbeauftragte; KI-Verantwortliche; Testverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: DER.1, APP.6; ISO: ISO/IEC 27001:2022 6.1, ISO/IEC 23894:2023

Quellen

[Q-BSI-001] S. 12–16; [Q-BSI-2003-001] S. 5–7, S. 26–28 und S. 33–35; [Q-NIST-002] Taxonomie der Angriffe und Abhilfen; [Q-MITRE-001] Tactics and techniques; [Q-OWASP-001] LLM Top 10 2025³⁰

³⁰ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 12–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: BSI-Standard 200-3: Risikomanagement, Version 1.0, Stand Oktober 2017, S. 5–7, S. 26–28 und S. 33–35, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/BSI_Standards/standard_200_3.pdf?__blob=publicationFile&v=2, abgerufen am 03.09.2026. | National Institute of Standards and Technology: Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations, NIST AI 100-2 E2025, Stand Finalfassung 2025, veröffentlicht am 24.03.2025, Taxonomie der Angriffe und Abhilfen, <https://csrc.nist.gov/pubs/ai/100/2/e2025/final>, abgerufen am 02.09.2026. | The MITRE Corporation: MITRE ATLAS, Laufend gepflegte Wissensbasis, Abrufstand 02.09.2026, Tactics and techniques,

KI-THR-002 – Ressourcen-, Missbrauchs- und Verfügbarkeitsgrenzen

Normative Anforderung

Eingabe-, Kontext- und Ausgabemenge, Datei- und Stapelgröße, Anzahl gleichzeitiger Anfragen, Laufzeit, Speicher, Beschleuniger, Suchtreffer und Werkzeugaufrufe MÜSSEN je Identität und Dienst begrenzt werden. Missbrauch und Ressourcenerschöpfung MÜSSEN erkannt, gedrosselt und kontrolliert beendet werden.

Begründung

Lange Kontexte, rekursive Agentenschleifen und aufwendige Anfragen können lokale Kapazität erschöpfen und andere Dienste verdrängen.

Umsetzung im Geltungsbereich

Quoten, Zeitüberschreitungen, Warteschlangensteuerung, automatische Unterbrechung bei Überlastung, Prioritäten und Kapazitätsreserven werden zentral konfiguriert. Kritische Basisdienste bleiben von KI-Ressourcen entkoppelt.

Prüfziel

Last-, Grenzwert- und Missbrauchstests müssen faire Begrenzung, sichere Beendigung, Alarmierung und Wiederherstellung ohne Datenkorruption belegen.

Erwartete Nachweise

Kapazitätsmodell; Grenzwertkonfiguration; Lasttests; Alarmregeln; Drosselungsprotokolle; Wiederherstellungsnachweis.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Entwurf; Test; Betrieb; Kapazitätsverantwortliche; Plattformverantwortliche; Betriebsverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: OPS.1.1.1, DER.1; ISO: ISO/IEC 27002:2022 8.6, ISO/IEC 27002:2022 8.16

Quellen

[Q-BSI-001] S. 14–16; [Q-OWASP-001] Ressourcenverbrauch; [Q-NIST-001] Measure- und Manage-Aktionen³¹

<https://atlas.mitre.org/>, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, LLM Top 10 2025, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026.

³¹ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 14–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, Ressourcenverbrauch, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, Stand 26.07.2024, Measure- und Manage-Aktionen, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026.

9.14 Bewertung, Freigabe, Wiederholungsprüfung und Rückkehr zur Vorversion

KI-VAL-001 – Wiederholbare Qualitäts- und Sicherheitsbewertung

Normative Anforderung

Vor Erstfreigabe MUSS jede Modell-Laufzeit-Anwendungsfall-Kombination anhand repräsentativer, getrennt verwalteter Testfälle auf fachliche Qualität, Robustheit, Datenschutz und Sicherheit bewertet werden. Schwellenwerte, Messgrößen, Datensätze, Zufallsparameter, Umgebung und Ergebnisse MÜSSEN dokumentiert und wiederholbar sein.

Begründung

Allgemeine Vergleichstests belegen weder Eignung noch Sicherheit im lokalen Anwendungsfall. Modellantworten sind variabel und benötigen wiederholbare Messungen.

Umsetzung im Geltungsbereich

Eine fachliche Testfallsammlung, Missbrauchsfälle und unabhängige Angriffstests sowie klare Abnahmeschwellen werden vor dem Test festgelegt. Unabhängige qualifizierte Personen prüfen wesentliche Ergebnisse.

Prüfziel

Eine Stichprobe muss mit derselben Konfiguration reproduzierbar sein; unterschrittene Schwellenwerte müssen die Freigabe blockieren.

Erwartete Nachweise

Testplan; versionierte Testdaten; Definitionen der Messgrößen; Laufzeit- und Parameterstand; Roh- und Ergebnisdaten; unabhängige Prüfung; Freigabeentscheidung.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Test; Freigabe; Testverantwortliche; Fachverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: OPS.1.1.6, APP.6; ISO: ISO/IEC 42001:2023 A.7, ISO/IEC 25059:2023

Quellen

[Q-BSI-001] S. 9–12; [Q-BMVG-001] S. 29–32; [Q-NIST-001] Measure-Aktionen; [Q-ISO-25059] öffentliche Metadaten zum KI-Qualitätsmodell³²

³² Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 9–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 29–32, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, Stand 26.07.2024, Measure-Aktionen, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026. | International Organization for Standardization / International Electrotechnical Commission: Software engineering

KI-VAL-002 – Änderungsabhängige Wiederholungsprüfung, Wiederfreigabe und Rückkehr zur Vorversion

Normative Anforderung

Änderungen an Modell, Modellkomprimierung, Laufzeit, Systemanweisung, RAG-Daten oder -Logik, Suchvektoren, Treffer-Neusortierung, kontrolliertem KI-Zugang, Werkzeugen und Sicherheitsparametern MÜSSEN risikobasierte Wiederholungsprüfungen und eine Wiederfreigabe auslösen. Bei Abweichungen MUSS die getestete Rückkehr zur freigegebenen Vorversion verfügbar sein.

Begründung

KI-Verhalten entsteht aus der gesamten Kette. Eine scheinbar kleine Komponentenänderung kann Qualität, Sicherheit oder Berechtigungswirkung verschieben.

Umsetzung im Geltungsbereich

Eine Änderungsmatrix ordnet Komponenten konkrete Tests zu. Automatisierte Vergleiche erkennen Verschlechterungen von Sicherheit und Qualität; Freigabemanifeste erlauben einen vollständigen Wechsel und die Rückkehr zur Vorversion.

Prüfziel

Für jede Änderung die ausgelösten Tests, Entscheidung und erfolgreiche Rückkehr zur vorherigen freigegebenen Kombination nachweisen.

Erwartete Nachweise

Änderungsantrag; Auswirkungsanalyse; Ergebnisse der Wiederholungsprüfungen; neues Freigabemanifest; Rückkehrplan und Rückkehrtest; Kommunikationsnachweis.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Änderung; Test; Freigabe; Änderungsverantwortliche; Testverantwortliche; Betriebsverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschatz: OPS.1.1.3, OPS.1.1.6; ISO: ISO/IEC 27002:2022 8.32, ISO/IEC 5338:2023

Quellen

[Q-BSI-001] S. 8 und S. 11–12; [Q-BMVG-001] S. 29–32 und S. 45–47; [Q-ISO-5338] öffentliche Lebenszyklusmetadaten³³

— SQuaRE — Quality model for AI systems, ISO/IEC 25059:2023, Stand ISO-Metadaten, Ausgabe 2023-06, veröffentlicht am 01.06.2023, öffentliche Metadaten zum KI-Qualitätsmodell, <https://www.iso.org/standard/80655.html>, abgerufen am 02.09.2026.

³³ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 8 und S. 11–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 29–32 und S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — AI system life cycle processes, ISO/IEC 5338:2023, Stand ISO-Metadaten, Ausgabe 2023-12,

9.15 Protokollierung, Überwachung, Verhaltensänderungen, Vorfälle und Wiederanlauf

KI-OPS-001 – Datensparsame und manipulationsgeschützte KI-Protokollierung

Normative Anforderung

Sicherheitsrelevante KI-Ereignisse MÜSSEN lokal, zeitlich synchronisiert, identitätsbezogen und manipulationsgeschützt protokolliert werden. Erforderlich sind mindestens Modell- und Richtlinienversion, Zugriff, Werkzeugaufruf, Freigabe, Blockierung, Grenzwertverletzung, Administrationsänderung und Vorfallbezug; Inhaltsdaten DÜRFEN nur zweckgebunden und minimiert gespeichert werden.

Begründung

Ohne technische Kontextdaten lassen sich Modellverhalten und Agentenwirkungen nicht untersuchen; vollständige Eingaben können zugleich sensible Inhalte und Geheimnisse vervielfachen.

Umsetzung im Geltungsbereich

Ein Protokollierungskonzept trennt Sicherheitsmetadaten, optionale Inhaltsprotokolle und Prüfdaten. Es legt Zugriff, Aufbewahrung, Integrität, Löschung und die Verknüpfung in der lokalen Sicherheitsauswertung fest.

Prüfziel

Aus einem Testvorfall die verantwortliche Identität, wirksame Modell- und Richtlinienversion sowie Werkzeugkette rekonstruieren, ohne unnötige Inhaltsdaten offenzulegen.

Erwartete Nachweise

Protokollierungskonzept; Beispieldatensätze; Zeit- und Integritätsnachweis; Regeln der zentralen Sicherheitsauswertung; Zugriffs- und Löschprüfung; Rekonstruktionsübung.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Betrieb; Vorfall; Prüfung; Protokollierungsverantwortliche; Datenschutzbeauftragte; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: OPS.1.1.5, DER.1; ISO: ISO/IEC 27002:2022 8.15, ISO/IEC 27002:2022 8.17

Quellen

[Q-BSI-001] S. 12–13; [Q-BMVG-001] S. 23–26 und S. 45–47; [Q-DSK-002] Kap. 2–6³⁴

veröffentlicht am 01.12.2023, öffentliche Lebenszyklusmetadaten, <https://www.iso.org/standard/81118.html>, abgerufen am 02.09.2026.

³⁴ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 12–13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 23–26 und S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu empfohlenen technischen und organisatorischen Maßnahmen bei der Entwicklung und beim Betrieb von KI-Systemen, Version 1.0,

KI-OPS-002 – Überwachung, schleichende Verhaltensänderungen und KI-Vorfallbehandlung

Normative Anforderung

Qualität, Fehlerraten, Ablehnungen, Ressourcenverbrauch, Richtlinienverstöße, Anzeichen eingeschleuster Anweisungen, Auffälligkeiten der lokalen Wissensuche sowie schleichende Modell- oder Konfigurationsänderungen MÜSSEN risikoorientiert überwacht werden. KI-spezifische Vorfälle MÜSSEN in den allgemeinen Vorfallprozess integriert und mit Abschaltmöglichkeiten sowie der Rückkehr zur freigegebenen Vorversion behandelt werden.

Begründung

Verschlechterungen und Angriffe zeigen sich häufig zuerst in Messgrößen der Ausgaben oder Nutzung und nicht in klassischen Alarmmeldungen des Serverbetriebssystems.

Umsetzung im Geltungsbereich

Freigegebener Ausgangsstand, Schwellenwerte, Alarmwege, Leitfäden zur Ersteinschätzung und sichere Betriebsarten mit vermindertem Funktionsumfang werden festgelegt. Vorfallsübungen umfassen Datenabfluss, manipulierte RAG-Quellen, kompromittierte Modelle und Agentenfehlaktionen.

Prüfziel

Künstliche Abweichungen müssen erkannt, richtig priorisiert und bis zu Eindämmung, Beweissicherung, Wiederherstellung und Nachbereitung bearbeitet werden.

Erwartete Nachweise

Überwachungskonzept; Übersichten; Alarmregeln; Bericht zu Verhaltensänderungen; Vorfalleitfäden; Übungsprotokolle; Korrektur- und Rückkehrnachweise.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Betrieb; Vorfall; Änderung; Betriebsverantwortliche; Informationssicherheitsbeauftragte; Vorfallverantwortliche; Modellverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: DER.1, DER.2.1; ISO: ISO/IEC 27002:2022 8.16, ISO/IEC 27002:2022 5.24

Quellen

[Q-BMVG-001] S. 31–32 und S. 45–47; [Q-BSI-001] S. 8 und S. 12–16; [Q-NIST-001] Measure- und Manage-Aktionen³⁵

Stand Juni 2025, veröffentlicht am 17.06.2025, Kap. 2–6, https://www.datenschutzkonferenz-online.de/media/oh/DSK-OH_KI-Systeme.pdf, abgerufen am 02.09.2026.

³⁵ Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 31–32 und S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 8 und S. 12–16, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, Stand

KI-OPS-003 – Wiederanlauf und konsistente Sicherungen

Normative Anforderung

Wiederanlauf- und Sicherungsverfahren MÜSSEN die konsistente Kombination aus Modell, Laufzeit, Richtlinien des kontrollierten KI-Zugangs, Systemanweisungen, RAG-Quellen, Index, Metadaten der Zugriffsregeln, Konfiguration und Nachweisen berücksichtigen. Wiederherstellungen MÜSSEN regelmäßig ohne Internetzugang erprobt werden.

Begründung

Ein technisch gestarteter Dienst ist nicht betriebsfähig, wenn Modell, Index, Berechtigungen oder Freigabestand auseinanderfallen.

Umsetzung im Geltungsbereich

Versionierte Sicherungssätze und Wiederanlaufreihenfolge stellen Identitäten und Richtlinien vor Daten- und KI-Funktionen bereit. Nach Wiederherstellung erfolgen Integritäts-, Berechtigungs- und Wiederholungsprüfungen.

Prüfziel

Aus freigegebenen Sicherungen eine konsistente Umgebung wiederherstellen und Prüfsummen, Zugriffsrechte, Kernfunktionen sowie den Betrieb ohne Internetverbindung nachweisen.

Erwartete Nachweise

Sicherungsmatrix; Wiederanlaufplan; Wiederherstellungstest ohne Internetzugang; Integritäts- und Berechtigungsprüfung; Wiederanlaufzeiten; Abweichungsbehandlung.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Betrieb; Notfall; Wiederanlauf; Backup-Verantwortliche; Betriebsverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: CON.3, DER.4; ISO: ISO/IEC 27002:2022 8.13, ISO/IEC 27002:2022 5.30

Quellen

[Q-BSI-001] S. 11–13; [Q-NCSC-001] Secure operation and maintenance; [Q-BMVG-001] S. 45–47³⁶

26.07.2024, Measure- und Manage-Aktionen, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026.

³⁶ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 11–13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development, Version 1.0, Stand November 2023, veröffentlicht am 26.11.2023, Secure operation and maintenance, <https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/about-this-document>, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026.

9.16 Außerbetriebnahme und nachweisbare Löschung

KI-DEC-001 – Kontrollierte Außerbetriebnahme

Normative Anforderung

Bei Außerbetriebnahme eines Modells, Dienstes, RAG-Bestands, Werkzeugs oder Anwendungsfalls MÜSSEN Zugänge widerrufen, Endpunkte entfernt, Aufgaben beendet, Modelle und Daten nach Aufbewahrungsregeln gelöscht, lokale Registrierungen bereinigt und Nachweise revisionsgeeignet abgeschlossen werden.

Begründung

Verwaiste Endpunkte, Konten, Indizes, Zwischenspeicher oder Modellkopien bleiben sonst erreichbar und entziehen sich Aktualisierungs-, Rechte- und Löschprozessen.

Umsetzung im Geltungsbereich

Eine objektbezogene Prüfliste umfasst Identitäten, Zertifikate, Geheimnisse, Netze, automatisierte Aufgaben, Speicher, Sicherungen, Protokolle, Lizenzen und abhängige Anwendungsfälle. Fachwissen bleibt in kontrollierten Quellen und wird nicht aus Modellgewichten übertragen.

Prüfziel

Für eine Testaußerbetriebnahme nachweisen, dass keine aktive Erreichbarkeit oder unzulässige Datenkopie verbleibt und erforderliche Nachweise erhalten sind.

Erwartete Nachweise

Außerbetriebnahmeauftrag; Widerrufs- und Netztest; Löschprotokolle; Registerabgleich; Sicherheitsbehandlung; Abschlussfreigabe.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Außerbetriebnahme; Löschung; Systemverantwortliche; Datenverantwortliche; Identitätsverantwortliche; Informationssicherheitsbeauftragte
Orientierende Zuordnung	BSI/IT-Grundschutz: CON.6, OPS.1.1.2; ISO: ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 5.11

Quellen

[Q-BSI-001] S. 13; [Q-DSK-001] Beendigung; [Q-BMVG-001] S. 45–47³⁷

³⁷ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Künstliche Intelligenz und Datenschutz, Version 1.0, Stand 06.05.2024, Beendigung, https://www.datenschutzkonferenz-online.de/media/oh/20240506_DSK_Orientierungshilfe_KI_und_Datenschutz.pdf, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026.

9.17 Bedingte Anforderungen für externe Inferenz

KI-EXT-001 – Neue Bewertung vor externer Inferenz

Normative Anforderung

Wenn externe Inferenz aktiviert werden soll, MUSS vor jeder Datenübertragung eine neue organisationsspezifische Bewertung und Freigabe mindestens Datenschutz, Klassifikation, Verträge, Auftragsverarbeitung, Drittlandbezug, Anbieter und Lieferkette, Protokollierung, Löschung, Aufbewahrung, Verschlüsselung, Schlüsselverwaltung, Verfügbarkeit, Vorfälle und Ausstieg abdecken. Ohne abgeschlossene Freigabe DARF keine externe Inferenz erfolgen.

Begründung

Eingaben, Systemanweisungen, Kontexte, RAG-Ausschnitte, Dateiübernahmen, Metadaten und Ausgaben werden beim externen Betreiber verarbeitet; Transportverschlüsselung beseitigt diese Verarbeitung nicht.

Umsetzung im Geltungsbereich

Vor der Aktivierung werden Dokumentenstatus, Systemgrenze und Datenflussmodell aktualisiert sowie gesonderte Kontroll- und Vertragsnachweise freigegeben. Zulässige Daten und Endpunkte werden technisch aufgelistet.

Prüfziel

Vor einer kontrollierten Testanfrage prüfen, ob sämtliche Freigabebedingungen erfüllt sind und nicht freigegebene Daten beziehungsweise Endpunkte blockiert werden.

Erwartete Nachweise

Neue Risiko- und Datenschutzbewertung; Datenflussmodell; Verträge; Anbieterprüfung; Schlüssel- und Löschkonzept; Freigabe; negative Datentests.

Steuermerkmal	Ausprägung
Anwendbarkeit	bedingt-externe-inferenz
Lebenszyklus und Rollen	Planung; Beschaffung; Freigabe; Betrieb; Leitung; Datenschutzbeauftragte; Informationssicherheitsbeauftragte; Rechtsstelle; Beschaffung
Orientierende Zuordnung	BSI/IT-Grundschutz: OPS.2.2, CON.2; ISO: ISO/IEC 27002:2022 5.19, ISO/IEC 27002:2022 5.20, ISO/IEC 42001:2023 A.10

Quellen

[Q-BMI-001] S. 25–29; [Q-BSI-001] S. 4–5 und S. 9–12; [Q-BFDI-001] Kap. 1–7; [Q-EU-001] Art. 26–27³⁸

³⁸ Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, PDF-Stand 07.04.2025, S. 25–29, <https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 4–5 und S. 9–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit: KI in Behörden – Datenschutz von Anfang an mitdenken, Handreichung für die

KI-EXT-002 – Keine automatische externe Ausweichverbindung

Normative Anforderung

Cloud-Modelle, automatische Erkennung externer Anbieter, externe Telemetrie und Ausweichverbindungen zu externen Endpunkten MÜSSEN standardmäßig deaktiviert sein. Eine aktivierte externe Variante MUSS jeden zulässigen Betreiber, Endpunkt, Modell- und Datenumfang ausdrücklich festlegen; nicht bekannte Ziele MÜSSEN technisch blockiert werden.

Begründung

Automatische Ausweichverbindungen können bei Fehlern oder Kapazitätsengpässen gerade dann Daten extern übertragen, wenn reguläre Kontrollen nicht aufmerksam beobachtet werden.

Umsetzung im Geltungsbereich

Clientkonfiguration und kontrollierter KI-Zugang, Namensauflösung, Proxy und Firewall verwenden positive Zulässigkeitslisten. Tests erzwingen den Ausfall lokaler Modelle und bestätigen, dass keine externe Ersatzverbindung entsteht.

Prüfziel

Bei Ausfall, Fehlkonfiguration und manipulierten Anbieterangaben darf kein nicht freigegebener externer Datenfluss entstehen.

Erwartete Nachweise

Anbieter- und Endpunktliste; Regeln für ausgehenden Netzwerkverkehr; freigegebener Clientausgangsstand; Ausfall- und Ausweichverbindungstests; DNS-/Proxyprotokolle; Alarmnachweis.

Steuermerkmal	Ausprägung
Anwendbarkeit	bedingt-externe-inferenz
Lebenszyklus und Rollen	Einführung; Test; Betrieb; Clientverantwortliche; Verantwortliche für den KI-Zugang; Netzverantwortliche
Orientierende Zuordnung	BSI/IT-Grundschutz: NET.1.1, APP.6; ISO: ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.26

Quellen

[Q-CLINE-001] Providerkonfiguration; [Q-OPENCODE-001] Provider und lokale Modelle; [Q-BSI-001] S. 9–12³⁹

Bundesverwaltung, Stand 22.12.2025, Kap. 1–7, https://www.bfdi.bund.de/SharedDocs/Downloads/DE/DokumenteBfDI/Dokumente-allg/2025/Handreichung-KI.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Europäische Union: Verordnung (EU) 2024/1689 über künstliche Intelligenz, ABl. L 2024/1689, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 12.07.2024, Art. 26–27, <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>, abgerufen am 02.09.2026.

³⁹ Cline Bot Inc.: Cline Model Providers, Commit 0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710, Commit vom 12.05.2026, Providerkonfiguration, <https://github.com/cline/cline/blob/0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710/docs/sdk/model-providers.mdx>, abgerufen am 02.09.2026. | Anomaly Innovations Inc.: OpenCode Models, Version 2, Online-Dokumentation, Abrufstand 02.09.2026, Provider und lokale Modelle, <https://opencode.ai/v2/docs/models>, abgerufen am 02.09.2026. | Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 9–12, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

9.18 Nachweise, Ausnahmen und akzeptierte Restrisiken

KI-ASS-001 – Prüfbare Nachweiskette und befristete Abweichungen

Normative Anforderung

Für jede anwendbare Kontrolle MÜSSEN verantwortliche Rolle, Umsetzungsstatus, prüfbarer Nachweis, Prüfdatum, Ergebnis und nächste Prüfung geführt werden. Abweichungen MÜSSEN Risiko, kompensierende Maßnahmen, Befristung, Genehmigende und Ausstiegskriterium enthalten; akzeptierte Restrisiken DÜRFEN nicht als erfüllte Kontrolle dargestellt werden.

Begründung

Eine dokumentierte Anforderung ist ohne aktuellen Wirksamkeitsnachweis nicht prüfbar. Unklare Ausnahmen können dauerhaft und unsichtbar werden.

Umsetzung im Geltungsbereich

Ein kontrolliertes Nachweisregister referenziert unveränderbare Artefakte und trennt Entwurf, umgesetzt, geprüft, abweichend und nicht anwendbar. Zugriff und Aufbewahrung richten sich nach dem Nachweisschutzbedarf.

Prüfziel

Für eine Stichprobe die lückenlose Kette von Kontroll-ID über Umsetzung und Prüfung bis zu Abweichung oder Freigabe nachvollziehen.

Erwartete Nachweise

Nachweisregister; Prüfprotokolle; kryptografische Prüfsummen der Nachweise; Ausnahme- und Restrisikoregister; Genehmigungen; Wiedervorlagen; Abschlusskriterien.

Steuermerkmal	Ausprägung
Anwendbarkeit	standard
Lebenszyklus und Rollen	Gesamter-Lebenszyklus; Kontrollverantwortliche; Prüfende; Risikoverantwortliche; Leitung
Orientierende Zuordnung	BSI/IT-Grundschutz: ISMS.1, DER.3.1; ISO: ISO/IEC 27001:2022 7.5, ISO/IEC 27001:2022 9.1, ISO/IEC 42001:2023 9.1

Quellen

[Q-BSI-001] S. 8–13; [Q-BMVG-001] S. 25–32 und S. 45–47; [Q-NIST-001] Govern-, Measure- und Manage-Aktionen⁴⁰

⁴⁰ Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 8–13, https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026. | Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 25–32 und S. 45–47, <https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026. | National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, Stand 26.07.2024, Govern-, Measure- und Manage-Aktionen, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026.

10 Lokale Wissenssuche, Dateiübernahmen und Daten

Fachwissen verbleibt außerhalb der Modellgewichte. Die lokale Wissenssuche und zeitlich begrenzte lokale Dateiübernahmen sind die einzigen vorgesehenen Zuführungswege. Dateien durchlaufen Quarantäne, Schadsoftware- und Typprüfung sowie eine isolierte Auswertung. Herkunft, Eigentümer, Schutzbedarf und Zugriffsregeln bleiben an allen abgeleiteten Daten erhalten.

Aufnahme und Abfrage sind getrennte Wege. Vor der Aufnahme und erneut bei jeder Abfrage wird die Berechtigung anhand der aktuellen Identität geprüft. Nur freigegebene Treffer gelangen in den Kontext der lokalen Inferenz; eine Löschung erfasst Quelle, Ableitungen, Index, Zwischenspeicher und Sicherungskette (Abbildung 5).

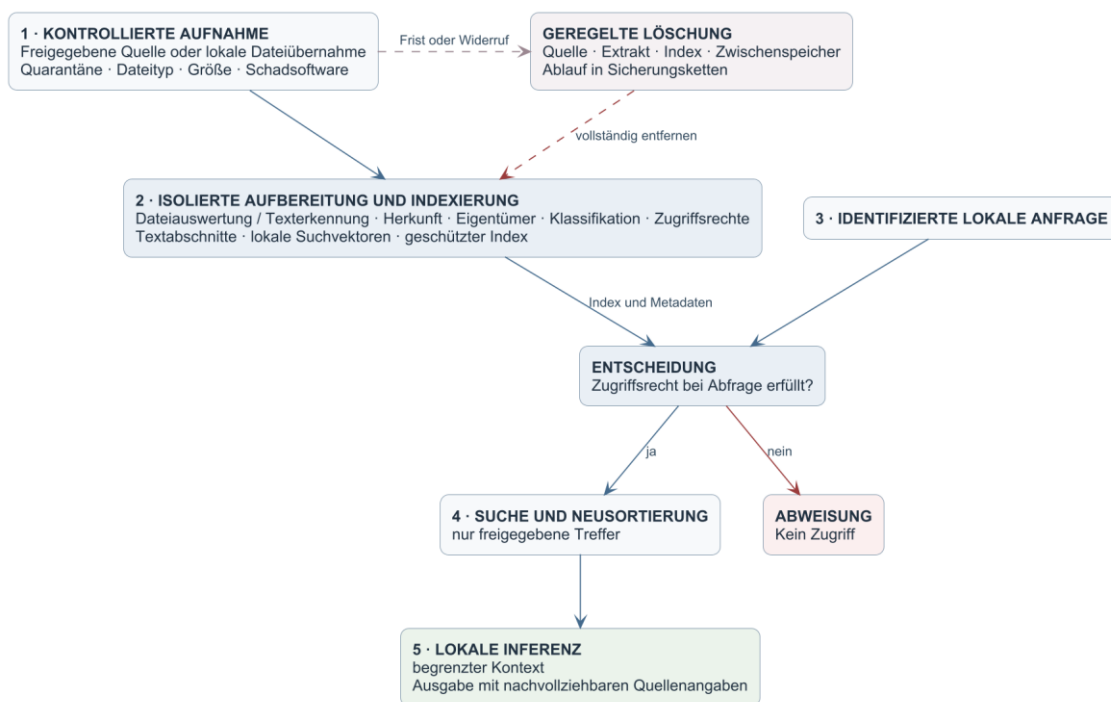


Abbildung 5: Aufnahme, berechtigte Abfrage und vollständige Löschung bleiben technisch getrennt.

- Suchvektoren, Textabschnitte, Indizes, Zwischenspeicher und Daten zur Neusortierung erhalten mindestens den Schutzbedarf der Quelldaten.
- Das Sprachmodell und Systemanweisungen treffen keine Zugriffsentscheidung.
- Bedarfsgesteuerte Dateiübernahmen bleiben ohne ausdrückliche Genehmigung einer dauerhaften Ablage sitzungsbezogen.
- Ausgaben weisen verwendete Quellen und konkrete Fundstellen nachvollziehbar aus.
- Löschung umfasst Onlinekopien, Ableitungen, Zwischenspeicher und den geregelten Ablauf in Sicherungsketten.

Indexierung und die Erzeugung von Suchvektoren ändern keine Modellgewichte. Training, Feinabstimmung und jede lernende Rückkopplung aus Chats, Dateiübernahmen oder Wissensbeständen bleiben technisch und organisatorisch ausgeschlossen.

11 Agentische Anwendungen und lokale Entwicklungsumgebungen

Agentische Clients wie Cline- oder OpenCode-artige Werkzeuge sind Produktbeispiele. Sie greifen ausschließlich über den lokalen HTTPS-Zugang auf freigegebene Modelle zu. Lokale Git-, Paket- und Entwicklungsdienste bleiben in der Organisationsumgebung.

Eine Modellausgabe löst keine unmittelbare Werkzeugaktion aus. Werkzeugrichtlinie, Prüfung der möglichen Wirkung, konkrete menschliche Bestätigung und eine minimal berechnete Ausführungsumgebung bilden voneinander unabhängige Schranken (Abbildung 6).

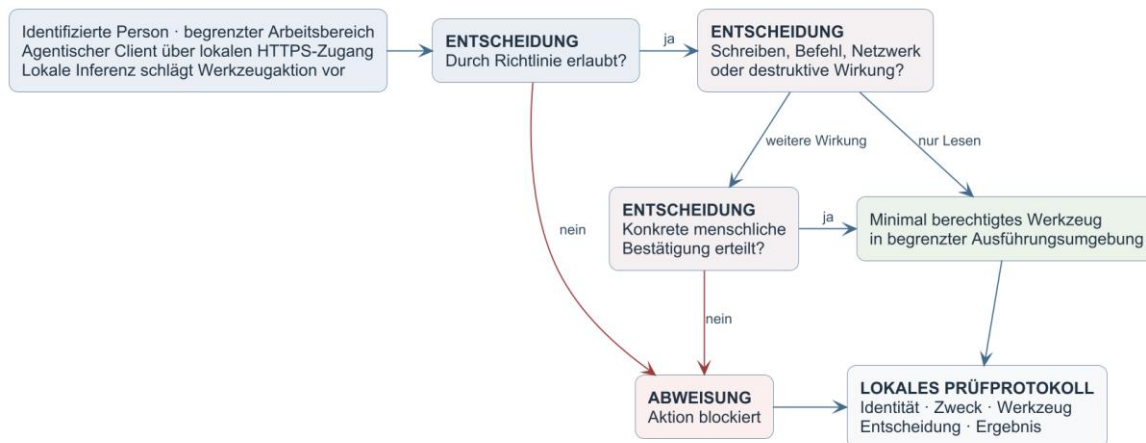


Abbildung 6: Eine Werkzeugaktion benötigt Richtlinienprüfung, begrenzte Rechte und bei erhöhter Wirkung eine konkrete Bestätigung.

- Arbeitsbereichs- und Dateirechte sind minimal und überschreiten weder Projekt noch genehmigten Zweck.
- Lesen, Schreiben, Befehlsausführung und Netzwerkzugriff sind getrennte Fähigkeiten.
- Kritische, destruktive, privilegierte oder externe Aktionen benötigen eine konkrete menschliche Bestätigung.
- Eingeschleuste Anweisungen aus Quellcode, Dokumenten, Webseiten und Werkzeugausgaben dürfen keine Rechte erweitern.
- Plug-ins, MCP-Server, Erweiterungen und Pakete stammen aus kontrollierten lokalen Quellen und sind versionsfixiert.
- Werkzeugaufrufe werden identitätsbezogen, nachvollziehbar und datensparsam lokal protokolliert.

12 Betrieb, Änderung, Modellwechsel, Vorfälle und Außerbetriebnahme

Der Betrieb verbindet den freigegebenen Systemstand, lokale Protokollierung, zentrale Sicherheitsauswertung (SIEM), Qualitäts- und Sicherheitskennzahlen, Beobachtung schleichender Verhaltensänderungen, Kapazitätsgrenzen und den allgemeinen Vorfallprozess. Der reine technische Betrieb belegt weder korrekte Berechtigungen noch Ergebnisqualität, Datenlöschung oder Wiederherstellbarkeit.

Jede Änderung an Modell, Modellkomprimierung, Laufzeit, Systemanweisung, lokaler Wissenssuche, Suchvektoren, Treffer-Neusortierung, kontrolliertem KI-Zugang, Werkzeugen oder Sicherheitsparametern löst eine risikobasierte Wiederholungsprüfung und Wiederfreigabe aus. Vorherige geprüfte Kombinationen bleiben für eine kontrollierte Rückkehr verfügbar. Wiederanlaufprüfungen erfolgen ohne Internetzugang und umfassen Prüfsummen, Richtlinien, Zugriffsregeln und Kernbewertungen.

Bei Außerbetriebnahme werden Identitäten, Zertifikate, Geheimnisse, Endpunkte, automatisierte Aufgaben, Modelle, Daten, Indizes und Zwischenspeicher behandelt. Erforderliche Prüfnachweise bleiben entsprechend der Aufbewahrungsfrist erhalten; unzulässige Restkopien und Erreichbarkeit müssen durch Nachtests ausgeschlossen werden.

13 Nachweis-, Prüf- und Zuordnungsübersicht

Für jede anwendbare Kontrolle werden Umsetzung, verantwortliche Rolle, Prüfergebnis, Nachweisfundstelle, Abweichung und Restrisiko nachvollziehbar geführt. Die Zuordnungen unterstützen die gemeinsame Prüfung mit dem allgemeinen Informationssicherheitsmanagement.

ID	Titel	Anwendbarkeit	BSI/IT-Grundschutz	ISO-Kennungen
KI-GEL-001	Abgrenzung zum allgemeinen IT-Sicherheitskonzept	standard	ISMS.1, ORP.1	ISO/IEC 27001:2022 4.3, ISO/IEC 27001:2022 6.1
KI-GEL-002	Schutzkennzeichnung und kontrollierte Dokumentenführung	standard	ORP.1, CON.10	ISO/IEC 27001:2022 5.2, ISO/IEC 27002:2022 5.12
KI-GOV-001	KI-Inventar und eindeutige Verantwortung	standard	ORP.1, OPS.1.1.2	ISO/IEC 42001:2023 A.3, ISO/IEC 27001:2022 5.3
KI-GOV-002	Genehmigte Nutzung und KI-Kompetenz	standard	ORP.3, ORP.4	ISO/IEC 42001:2023 A.6, ISO/IEC 27002:2022 6.3
KI-GOV-003	Lebenszyklus-Risikosteuerung, Ausnahmen und Überprüfungen	standard	ISMS.1, OPS.1.1.3	ISO/IEC 27001:2022 6.1, ISO/IEC 42001:2023 6.1, ISO/IEC 23894:2023
KI-REC-001	Rechts- und Datenschutzprüfung je Anwendungsfall	standard	ORP.5, CON.2	ISO/IEC 42001:2023 4.2, ISO/IEC 27001:2022 4.2
KI-REC-002	Schutzbedarf und Geheimschutzfreigabe	standard	CON.10, ORP.4	ISO/IEC 27002:2022 5.12, ISO/IEC 27002:2022 5.13
KI-ARC-001	Explizite Zonen und einziger kontrollierter KI-Zugang	standard	NET.1.1, NET.3.2	ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.22
KI-ARC-002	Vollständig lokale Datenhaltung ohne ausgehende Internetverbindung	standard	NET.1.1, OPS.1.1.10	ISO/IEC 27002:2022 5.14, ISO/IEC 27002:2022 8.20
KI-CON-001	Standardmäßig verweiger-te Containerkommunikation	standard	APP.3.4, SYS.1.6	ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.22

ID	Titel	Anwendbarkeit	BSI/IT-Grundschatz	ISO-Kennungen
KI-CON-002	Minimale Containerprivilegien und unveränderbare Laufzeit	standard	SYS.1.6, OPS.1.1.2	ISO/IEC 27002:2022 8.9, ISO/IEC 27002:2022 8.27
KI-API-001	Zentrale Authentisierung und Autorisierung am KI-Zugang	standard	ORP.4, APP.6, CON.1	ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 5.16, ISO/IEC 27002:2022 8.5
KI-API-002	Serverseitige Modell-, Kontext-, Anfrage- und Werkzeuggrenzen	standard	APP.6, DER.1	ISO/IEC 27002:2022 8.26, ISO/IEC 27002:2022 8.28
KI-MOD-001	Kontrollierter Modellimport und Herkunftsnachweis	standard	OPS.1.1.10, OPS.1.1.6	ISO/IEC 27002:2022 5.21, ISO/IEC 27002:2022 8.19
KI-MOD-002	Versionierte Modellfreigabe und Rückkehr zur Vorversion	standard	OPS.1.1.3, OPS.1.1.6	ISO/IEC 42001:2023 A.6, ISO/IEC 5338:2023
KI-TRN-001	Keine Änderung von Modellgewichten	standard	APP.6, OPS.1.1.3	ISO/IEC 42001:2023 A.6, ISO/IEC 5338:2023
KI-RAG-001	Kontrollierte Aufnahme und isolierte Dokumentenaufbereitung	standard	APP.6, SYS.1.6	ISO/IEC 27002:2022 8.7, ISO/IEC 27002:2022 8.26
KI-RAG-002	Durchgängige Berechtigungsprüfung und Indextrennung	standard	ORP.4, APP.6	ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 8.3
KI-RAG-003	Schutz, Nachvollziehbarkeit und vollständige Löschung abgeleiteter Daten	standard	CON.6, CON.3	ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 8.13, ISO/IEC 5259-1:2024
KI-RAG-004	Sitzungsbezogene bedarfsgesteuerte Dateiübernahmen	standard	CON.6, APP.6	ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 8.12

ID	Titel	Anwendbarkeit	BSI/IT-Grundschutz	ISO-Kennungen
KI-IAM-001	Minimalrechte und Umgang mit Zugangsdaten und Geheimnissen für KI-Dienste	standard	ORP.4, CON.7	ISO/IEC 27002:2022 5.15, ISO/IEC 27002:2022 5.16, ISO/IEC 27002:2022 8.2
KI-AGT-001	Minimale lokale Arbeitsbereichs- und Dateirechte	standard	ORP.4, APP.6	ISO/IEC 27002:2022 8.2, ISO/IEC 27002:2022 8.18
KI-AGT-002	Lokale und freigegebene Modellendpunkte	standard	APP.6, NET.1.1	ISO/IEC 27002:2022 8.19, ISO/IEC 27002:2022 8.20
KI-PMT-001	Nicht vertrauenswürdige Inhalte und eingeschleuste Anweisungen	standard	APP.6, DER.1	ISO/IEC 27002:2022 8.26, ISO/IEC 27002:2022 8.28
KI-OUT-001	Prüfung, Kennzeichnung und menschliche Freigabe von Ausgaben	standard	APP.6, OPS.1.1.6	ISO/IEC 42001:2023 A.8, ISO/IEC 25059:2023
KI-TOL-001	Getrennte Werkzeugfunktionen und Bestätigung kritischer Aktionen	standard	ORP.4, APP.6	ISO/IEC 27002:2022 8.2, ISO/IEC 27002:2022 8.18
KI-TOL-002	Kontrollierte Erweiterungen, MCP-Server und Werkzeugprotokollierung	standard	OPS.1.1.10, OPS.1.1.5	ISO/IEC 27002:2022 5.21, ISO/IEC 27002:2022 8.15
KI-THR-001	KI-spezifisches Bedrohungsmodell	standard	DER.1, APP.6	ISO/IEC 27001:2022 6.1, ISO/IEC 23894:2023
KI-THR-002	Ressourcen-, Missbrauchs- und Verfügbarkeitsgrenzen	standard	OPS.1.1.1, DER.1	ISO/IEC 27002:2022 8.6, ISO/IEC 27002:2022 8.16
KI-VAL-001	Wiederholbare Qualitäts- und Sicherheitsbewertung	standard	OPS.1.1.6, APP.6	ISO/IEC 42001:2023 A.7, ISO/IEC 25059:2023
KI-VAL-002	Änderungsabhängige Wiederholungsprüfung, Wiederfreigabe und Rückkehr zur Vorversion	standard	OPS.1.1.3, OPS.1.1.6	ISO/IEC 27002:2022 8.32, ISO/IEC 5338:2023

ID	Titel	Anwendbarkeit	BSI/IT-Grundschutz	ISO-Kennungen
KI-OPS-001	Datensparsame und manipulationsgeschützte KI-Protokollierung	standard	OPS.1.1.5, DER.1	ISO/IEC 27002:2022 8.15, ISO/IEC 27002:2022 8.17
KI-OPS-002	Überwachung, schleichende Verhaltensänderungen und KI-Vorfallbehandlung	standard	DER.1, DER.2.1	ISO/IEC 27002:2022 8.16, ISO/IEC 27002:2022 5.24
KI-OPS-003	Wiederanlauf und konsistente Sicherungen	standard	CON.3, DER.4	ISO/IEC 27002:2022 8.13, ISO/IEC 27002:2022 5.30
KI-DEC-001	Kontrollierte Außerbetriebnahme	standard	CON.6, OPS.1.1.2	ISO/IEC 27002:2022 8.10, ISO/IEC 27002:2022 5.11
KI-EXT-001	Neue Bewertung vor externer Inferenz	bedingt-externe-inferenz	OPS.2.2, CON.2	ISO/IEC 27002:2022 5.19, ISO/IEC 27002:2022 5.20, ISO/IEC 42001:2023 A.10
KI-EXT-002	Keine automatische externe Ausweichverbindung	bedingt-externe-inferenz	NET.1.1, APP.6	ISO/IEC 27002:2022 8.20, ISO/IEC 27002:2022 8.26
KI-ASS-001	Prüfbare Nachweiskette und befristete Abweichungen	standard	ISMS.1, DER.3.1	ISO/IEC 27001:2022 7.5, ISO/IEC 27001:2022 9.1, ISO/IEC 42001:2023 9.1

14 Quellenverzeichnis und Abkürzungen

14.1 Quellenverzeichnis

[Q-BMI-001] Bundesministerium des Innern und für Heimat / Beratungszentrum für Künstliche Intelligenz: Leitlinien für den Einsatz Künstlicher Intelligenz in der Bundesverwaltung, Erstfassung, PDF-Stand 07.04.2025, S. 25–29; S. 30,
<https://www.bmi.bund.de/SharedDocs/downloads/DE/publikationen/themen/moderne-verwaltung/ki/BMI25020-leitlinien-ki-bundesverwaltung.html>, abgerufen am 02.09.2026.

[Q-BSI-001] Bundesamt für Sicherheit in der Informationstechnik: Kriterienkatalog des BSI zur Integration von extern bereitgestellten generativen KI-Modellen in eigene Anwendungen, Version 1.0, Stand 06.06.2025, S. 4–7; S. 8–10; S. 11–13; S. 14–16,
https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Kriterienkatalog_KI-Modelle_Bundesverwaltung.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

[Q-BSI-2002-001] Bundesamt für Sicherheit in der Informationstechnik: BSI-Standard 200-2: IT-Grundschutz-Methodik, Version 1.0, Stand Oktober 2017, S. 11 und S. 69–74; S. 154–156,
https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/BSI_Standards/standard_200_2.pdf?__blob=publicationFile&v=2, abgerufen am 03.09.2026.

[Q-BSI-2003-001] Bundesamt für Sicherheit in der Informationstechnik: BSI-Standard 200-3: Risikomanagement, Version 1.0, Stand Oktober 2017, S. 5–7; S. 26–28; S. 33–35,
https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Grundschutz/BSI_Standards/standard_200_3.pdf?__blob=publicationFile&v=2, abgerufen am 03.09.2026.

[Q-BMVG-001] Bundesministerium der Verteidigung: Künstliche Intelligenz, K-9000/102, Öffentliche Fassung, K-9000/102, Öffentliche Fassung, Gültigkeitsbeginn 09.04.2026, veröffentlicht am 04.08.2026, S. 23–26; S. 28–34; S. 45–50,
<https://www.bmvg.de/resource/blob/6143700/9954e2b6b993b17cd3d09ca31c506774/dl-ki-konzeption-data.pdf>, abgerufen am 02.09.2026.

[Q-BSI-SDT-001] Bundesamt für Sicherheit in der Informationstechnik: Stand-der-Technik-Bibliothek, Commit 8a97764ff4f23c2b7945c64344eecbf5a2053db2, Commit vom 27.08.2026, Repository-Inhalt und OSCAL-Katalog am fixierten Commit, <https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek/commit/8a97764ff4f23c2b7945c64344eecbf5a2053db2>, abgerufen am 02.09.2026.

[Q-NIST-OSCAL-001] National Institute of Standards and Technology: OSCAL Version 1.1.3 – Catalog JSON Schema, OSCAL 1.1.3, Stand Release vom 26.11.2024, Gesamtes Catalog-JSON-Schema, https://github.com/usnistgov/OSCAL/releases/download/v1.1.3/oscal_catalog_schema.json, abgerufen am 02.09.2026.

[Q-EU-001] Europäische Union: Verordnung (EU) 2024/1689 über künstliche Intelligenz, ABl. L 2024/1689, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 12.07.2024, Art. 2–4; Art. 9–15; Art. 26 und 27, <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>, abgerufen am 02.09.2026.

[Q-BFDI-001] Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit: KI in Behörden – Datenschutz von Anfang an mitdenken, Handreichung für die Bundesverwaltung, Stand

22.12.2025, Kap. 1–3; Kap. 4–7,

https://www.bfdi.bund.de/SharedDocs/Downloads/DE/DokumenteBfDI/Dokumente-allg/2025/Handreichung-KI.pdf?__blob=publicationFile&v=3, abgerufen am 02.09.2026.

[Q-DSK-001] Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Künstliche Intelligenz und Datenschutz, Version 1.0, Stand 06.05.2024, Gesamtdokument, insbesondere Auswahl, Einführung, Nutzung und Beendigung, https://www.datenschutzkonferenz-online.de/media/oh/20240506_DSK_Orientierungshilfe_KI_und_Datenschutz.pdf, abgerufen am 02.09.2026.

[Q-DSK-002] Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu empfohlenen technischen und organisatorischen Maßnahmen bei der Entwicklung und beim Betrieb von KI-Systemen, Version 1.0, Stand Juni 2025, veröffentlicht am 17.06.2025, Kap. 2–6, https://www.datenschutzkonferenz-online.de/media/oh/DSK-OH_KI-Systeme.pdf, abgerufen am 02.09.2026.

[Q-DSK-003] Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0, Stand Oktober 2025, veröffentlicht am 17.10.2025, Kap. 2–5, https://www.datenschutzkonferenz-online.de/media/oh/DSK_OH_RAG.pdf, abgerufen am 02.09.2026.

[Q-NIST-001] National Institute of Standards and Technology: Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, Stand 26.07.2024, Profile actions for Govern, Map, Measure and Manage, <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>, abgerufen am 02.09.2026.

[Q-NIST-002] National Institute of Standards and Technology: Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations, NIST AI 100-2 E2025, Stand Finalfassung 2025, veröffentlicht am 24.03.2025, Taxonomie der Angriffe und Abhilfen, <https://csrc.nist.gov/pubs/ai/100/2/e2025/final>, abgerufen am 02.09.2026.

[Q-ENISA-001] European Union Agency for Cybersecurity: Multilayer Framework for Good Cybersecurity Practices for AI, Erstveröffentlichung, Stand 2023, veröffentlicht am 15.11.2023, Multilayer framework und good practices, <https://www.enisa.europa.eu/publications/multilayer-framework-for-good-cybersecurity-practices-for-ai>, abgerufen am 02.09.2026.

[Q-NCSC-001] UK National Cyber Security Centre und internationale Partner: Guidelines for Secure AI System Development, Version 1.0, Stand November 2023, veröffentlicht am 26.11.2023, Secure design, development, deployment, operation and maintenance, <https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/about-this-document>, abgerufen am 02.09.2026.

[Q-OWASP-001] OWASP Foundation: OWASP Top 10 for Large Language Model Applications, Ausgabe 2025, Abrufstand 02.09.2026, LLM Top 10 2025, <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, abgerufen am 02.09.2026.

[Q-MITRE-001] The MITRE Corporation: MITRE ATLAS, Laufend gepflegte Wissensbasis, Abrufstand 02.09.2026, Tactics and techniques, <https://atlas.mitre.org/>, abgerufen am 02.09.2026.

[Q-K8S-001] The Kubernetes Authors: Kubernetes API Reference: NetworkPolicy v1, Online-Dokumentation, Abrufstand 02.09.2026, NetworkPolicySpec, ingress und egress, <https://kubernetes.io/docs/reference/kubernetes-api/networking/network-policy-v1/>, abgerufen am 02.09.2026.

[Q-DOCKER-001] Docker, Inc.: Rootless mode, Online-Dokumentation, Abrufstand 02.09.2026, Rootless mode, <https://docs.docker.com/engine/security/rootless/>, abgerufen am 02.09.2026.

[Q-PODMAN-001] Podman Project: podman-network, Online-Dokumentation, Abrufstand 02.09.2026, Network management und network create, <https://docs.podman.io/en/latest/markdown/podman-network.1.html>, abgerufen am 02.09.2026.

[Q-OLLAMA-001] Ollama: Authentication, Online-Dokumentation, Abrufstand 02.09.2026, Local access, <https://docs.ollama.com/api/authentication>, abgerufen am 02.09.2026.

[Q-VLLM-001] vLLM Project: Security, Online-Dokumentation, Abrufstand 02.09.2026, Security und API server, <https://docs.vllm.ai/en/stable/usage/security/>, abgerufen am 02.09.2026.

[Q-OPENWEBUI-001] Open WebUI: Starting with OpenAI-compatible providers, Online-Dokumentation, Abrufstand 02.09.2026, Connection to OpenAI-compatible providers, <https://docs.openwebui.com/getting-started/quick-start/connect-a-provider/starting-with-openai-compatible/>, abgerufen am 02.09.2026.

[Q-OPENWEBUI-002] Open WebUI: API Endpoints, Online-Dokumentation, Abrufstand 02.09.2026, Authentication und API endpoints, <https://docs.openwebui.com/reference/api-endpoints/>, abgerufen am 02.09.2026.

[Q-CLINE-001] Cline Bot Inc.: Cline Model Providers, Commit 0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710, Commit vom 12.05.2026, OpenAI-Compatible Providers, <https://github.com/cline/cline/blob/0b0ca9b1fa95ed9f3e0891a34f1f9b3904309710/docs/sdk/model-providers.mdx>, abgerufen am 02.09.2026.

[Q-OPENCODE-001] Anomaly Innovations Inc.: OpenCode Models, Version 2, Online-Dokumentation, Abrufstand 02.09.2026, Local models und provider configuration, <https://opencode.ai/v2/docs/models>, abgerufen am 02.09.2026.

[Q-LLAMACPP-001] ggml-org: llama.cpp, Commit ccc8fd2baa64ab26c7210b02765d3604069ec7ee, Stand README-Stand 23.08.2026, README und llama-server-Verweise, <https://github.com/ggml-org/llama.cpp/tree/ccc8fd2baa64ab26c7210b02765d3604069ec7ee>, abgerufen am 02.09.2026.

[Q-DAKKS-001] Deutsche Akkreditierungsstelle GmbH: Was ist Akkreditierung?, Online-Information, Abrufstand 02.09.2026, Begriffsdefinition Akkreditierung, <https://www.dakks.de/de/was-ist-akkreditierung.html>, abgerufen am 02.09.2026.

[Q-BSIG-001] Bundesrepublik Deutschland: Gesetz über das Bundesamt für Sicherheit in der Informationstechnik und über die Sicherheit in der Informationstechnik von Einrichtungen, BSIG 2025, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 02.12.2025, Anwendungsbezogen zu prüfende Vorschriften, https://www.gesetze-im-internet.de/bsig_2025/BJNR12D0B0025.html, abgerufen am 02.09.2026.

[Q-SUEG-001] Bundesrepublik Deutschland: Sicherheitsüberprüfungsgesetz, § 4 Verschlusssachen, SÜG, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 20.04.1994, § 4, https://www.gesetze-im-internet.de/s_g/_4.html, abgerufen am 02.09.2026.

[Q-VSA-001] Bundesministerium des Innern und für Heimat: Allgemeine Verwaltungsvorschrift zum materiellen Geheimschutz, Verschlusssachenanweisung, Stand Konsolidierter Stand am 02.09.2026 geprüft, veröffentlicht am 13.03.2023, Allgemeine Einstufungs- und Handhabungsregeln, https://www.verwaltungsvorschriften-im-internet.de/bsvwvbund_13032023_SII554001405.htm, abgerufen am 02.09.2026.

[Q-ISO-27001] International Organization for Standardization / International Electrotechnical Commission: Information security, cybersecurity and privacy protection — Information security management systems — Requirements, ISO/IEC 27001:2022, Stand ISO-Metadaten, Ausgabe 2022-10, veröffentlicht am 01.10.2022, Öffentliche Titelseite, Abstract und Metadaten, <https://www.iso.org/standard/27001>, abgerufen am 02.09.2026.

[Q-ISO-27002] International Organization for Standardization / International Electrotechnical Commission: Information security, cybersecurity and privacy protection — Information security controls, ISO/IEC 27002:2022, Stand ISO-Metadaten, Ausgabe 2022-02, veröffentlicht am 01.02.2022, Öffentliche Titelseite, Abstract und Metadaten, <https://www.iso.org/standard/75652.html>, abgerufen am 02.09.2026.

[Q-ISO-42001] International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — Management system, ISO/IEC 42001:2023, Stand ISO-Metadaten, Ausgabe 2023-12, veröffentlicht am 01.12.2023, Öffentliche Titelseite, Abstract und Metadaten, <https://www.iso.org/standard/42001>, abgerufen am 02.09.2026.

[Q-ISO-23894] International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — Guidance on risk management, ISO/IEC 23894:2023, Stand ISO-Metadaten, Ausgabe 2023-02, veröffentlicht am 01.02.2023, Öffentliche Titelseite, Abstract und Metadaten, <https://www.iso.org/standard/77304.html>, abgerufen am 02.09.2026.

[Q-ISO-42005] International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence (AI) — AI system impact assessment, ISO/IEC 42005:2025, Stand ISO-Metadaten, Ausgabe 2025-05, veröffentlicht am 01.05.2025, Öffentliche Titelseite, Abstract und Metadaten, <https://www.iso.org/standard/42005>, abgerufen am 02.09.2026.

[Q-ISO-5338] International Organization for Standardization / International Electrotechnical Commission: Information technology — Artificial intelligence — AI system life cycle processes, ISO/IEC 5338:2023, Stand ISO-Metadaten, Ausgabe 2023-12, veröffentlicht am 01.12.2023, Öffentliche Titelseite, Abstract und Metadaten, <https://www.iso.org/standard/81118.html>, abgerufen am 02.09.2026.

[Q-ISO-5259] International Organization for Standardization / International Electrotechnical Commission: Artificial intelligence — Data quality for analytics and machine learning (ML) — Part 1, ISO/IEC 5259-1:2024, Stand ISO-Metadaten, Ausgabe 2024-07, veröffentlicht am 01.07.2024,

Öffentliche Titelseite, Abstract und Metadaten, <https://www.iso.org/standard/81088.html>, abgerufen am 02.09.2026.

[Q-ISO-25059] International Organization for Standardization / International Electrotechnical Commission: Software engineering — SQuaRE — Quality model for AI systems, ISO/IEC 25059:2023, Stand ISO-Metadaten, Ausgabe 2023-06, veröffentlicht am 01.06.2023, Öffentliche Titelseite, Abstract und Metadaten, <https://www.iso.org/standard/80655.html>, abgerufen am 02.09.2026.

[Q-BSI-GSK-001] Bundesamt für Sicherheit in der Informationstechnik: IT-Grundschutz-Kompodium – öffentliche Baustein- und Anforderungskennungen, Über die Stand-der-Technik-Bibliothek fixierte Referenz, Stand Commitstand 27.08.2026, OSCAL-Katalog am fixierten Commit, <https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek/tree/8a97764ff4f23c2b7945c64344eecbf5a2053db2>, abgerufen am 02.09.2026.

14.2 Abkürzungen

Abkürzung	Langform	Abkürzung	Langform
ACL	Zugriffssteuerungsliste (Access Control List)	KI	Künstliche Intelligenz
API	Programmierschnittstelle (Application Programming Interface)	MFA	Mehrfaktorauthentisierung
BfDI	Die Bundesbeauftragte für den Datenschutz und die Informationsfreiheit	MCP	Model Context Protocol
BMI	Bundesministerium des Innern	OSCAL	Open Security Controls Assessment Language
BMVg	Bundesministerium der Verteidigung	RAG	Abrufgestützte Generierung (Retrieval Augmented Generation)
BSI	Bundesamt für Sicherheit in der Informationstechnik	SIEM	Zentrale Sammlung und Auswertung von Sicherheitsereignissen (Security Information and Event Management)
DSK	Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder	TLS	Transportverschlüsselung (Transport Layer Security)
IdP	Identitätsanbieter (Identity Provider)	VPN	Virtuelles privates Netz (Virtual Private Network)
ISMS	Informationssicherheitsmanagementsystem		